YTL*AI LABS

Z.AI

System Analysis Document (SA) — CliniFlow AI

Team Name : Dependency Free

Participant Name : Tang Shao Xian

1. Introduction

CliniFlow AI is an AI-powered clinical workflow platform designed to streamline and automate the end-to-end patient journey for small and medium-sized (SME) clinics in Malaysia. This System Analysis Documentation outlines the technical scope, architecture decisions, and design rationale behind the CliniFlow AI development.

1.1. Purpose

This system analysis document highlights the technical scope and design-related decisions behind the CliniFlow AI development.

The key elements of the system covered are as follows:

1. **Architecture:** CliniFlow AI uses a polyglot service architecture with a Spring Boot (Java) backend for business logic and a Python (FastAPI + LangGraph) agent service for AI orchestration. A pluggable OpenAI-compatible LLM provider serves as the central reasoning engine — currently OpenAI `gpt-4o-mini` for active development; Z.AI GLM 5.1 (via the ILMU platform, `ilmu-glm-5.1`) is the intended production target. Speech-to-text uses OpenAI Whisper (`whisper-1`) independently of the LLM provider.
2. **Data Flows:** How patient symptom data flows from the Next.js web UI, through the Spring Boot API gateway, to the Python agent service for LLM processing, gets stored in relational and graph knowledge base storage, and returns structured clinical documentation to the doctor.
3. **Model Process:** The model shows the end-to-end workflow of the core features: pre-visit symptom intake, AI-powered medical report generation during consultation (from live voice recording, uploaded audio, or text input), and post-visit patient summary generation.
4. **Role of Reference:** This document serves as a reference for understanding the overall high-level architecture, data flows, and technical decisions of the CliniFlow AI project.

1.2. Background

SME clinics in Malaysia face significant operational challenges due to high patient volumes, limited resources, and reliance on manual processes. Doctors spend 30–50% of their time on documentation rather than patient care, and fragmented systems lead to inconsistent patient data.

1. **Previous Version:** There is no previous version. Most Malaysian SME clinics currently rely on a mix of paper records and basic digital tools, with no integrated AI-driven workflow system.

2. **Changes in Major Architectural Components:** This is a greenfield project. The architecture introduces a novel polyglot design with Spring Boot (Java) handling DDD-structured business logic, and Python (FastAPI + LangGraph) handling all AI agent orchestration. The LLM integration uses an OpenAI-compatible endpoint configured against Z.AI GLM 5.1 (`ilmu-glm-5.1`) in both dev and prod; OpenAI is used **only** for Whisper speech-to-text.
3. **New Capabilities:** AI-powered symptom intake agent, automated SOAP medical report generation from live voice recording / voice upload / text input, an **AI safety evaluator** (4th Python agent — drug-allergy, drug-drug interaction, pregnancy, dose, hallucination, and completeness validators backed by a Neo4j drug knowledge graph), an adaptive rule learning component scoped strictly to documentation style (Hermes), multi-hop patient reasoning via the graph knowledge base, bilingual EN/MS patient-friendly post-visit summary, doctor scheduling with appointment booking, staff portal (today's waiting list, walk-in registration, check-in), admin portal (user management, analytics, PDPA audit log), and WhatsApp appointment/follow-up reminders via Twilio or Meta Cloud API.
4. **Project status (2026-05-02):** MVP flows implemented end-to-end and currently in hardening — registration, pre-visit intake, SOAP generation + doctor review with evaluator soft-block, post-visit bilingual summary, patient portal, staff portal, admin portal, scheduling, WhatsApp outbox drainer, and the Neo4j projection drainer are all wired.

1.3. Target Stakeholder

Stakeholders	Roles	Expectations
Clinic Doctors	Conduct consultations, review and edit AI-generated medical reports, validate clinical documentation	Reduced documentation time (≥50%), accurate AI-generated reports, easy review and editing lour workflow
Patients	Interact with symptom intake chatbot before visit, view post-visit records and medication instructions	Simple symptom reporting experience, clear and understandable post-visit instructions in plain language
Clinic Staff / Receptionists	Manage patient intake, access patient records, assist in administrative tasks	Pre-visit data available before appointment, structured and complete patient information
Clinic Administrators / Owners	Oversee operations, manage user accounts, view analytics	Centralized patient records, role-based access control, operational visibility
Development Team (Solo)	Build and maintain the full platform	Clear architecture documentation, modular codebase with DDD bounded contexts

---

2. System Architecture & Design

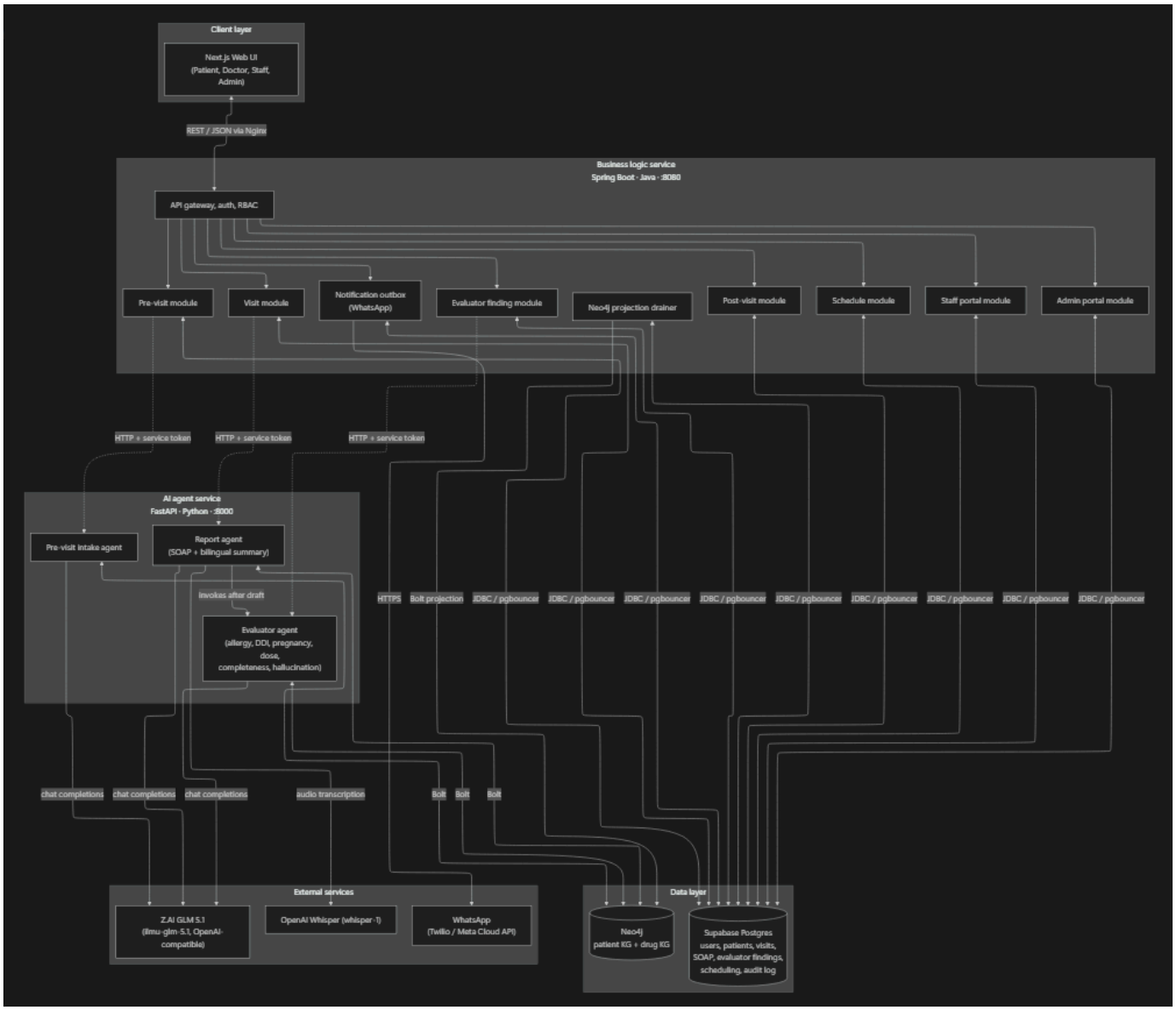
2.1. High Level Architecture

2.1.1. Overview

Type	Details
System	Web Application (Responsive)
Architecture	Polyglot Service Architecture (Spring Boot + Python Agent Service)

CliniFlow AI is structured as a polyglot client-server system with two backend services. The **Spring Boot (Java) service** handles API gateway responsibilities, authentication, role-based access control, patient record CRUD operations, scheduling and appointment booking, the WhatsApp notification outbox, the Neo4j projection drainer, and DDD-structured business logic across the patient, user, visit, schedule, and clinic bounded contexts. The **Python (FastAPI + LangGraph) agent service** handles all AI orchestration — four agents (Pre-Visit Intake, Report, Evaluator, and the Post-Visit summary tool that runs inside the Report agent on finalize), LLM API calls to Z.AI GLM 5.1 via an OpenAI-compatible client, Speech-to-Text via OpenAI Whisper, graph knowledge base queries (patient knowledge graph + drug knowledge graph), and adaptive rule (Hermes) management. Both services share a Supabase-hosted PostgreSQL database (accessed via pgbouncer in transaction mode) and a Neo4j database. The **Next.js 14 (App Router) frontend** ships four role-based portals — Patient, Doctor, Staff/Receptionist, and Clinic Admin/Owner — and communicates exclusively with the Spring Boot API (never directly with the Python agent or Neo4j). An Nginx reverse proxy fronts the stack on port 80, routing `/api/*` to Spring Boot and everything else to the Next.js server. The Python agent is internal-only and never exposed via Nginx. Calls from Spring Boot to the Python agent are wrapped in Resilience4j circuit breakers (`llm`, `stt`) with correlation-ID propagation.

Architecture Overview Diagram:



2.1.2. LLM as Service Layer

The LLM is integrated as the central reasoning engine within the Python agent service — not as a generic "AI Module." The provider is pluggable via an OpenAI-compatible HTTP client (`GLM_BASE_URL`, `GLM_API_KEY`, `GLM_MODEL` env vars). The current and only LLM target is **Z.AI GLM 5.1 via ILMU** (`api.ilmu.ai/v1`, model `ilmu-glm-5.1`) in both development and production — OpenAI is **not** used as an LLM. Speech-to-Text is a separate OpenAI Whisper integration (`OPENAI_BASE_URL`, `OPENAI_API_KEY`, model `whisper-1`) so the LLM provider can swap without affecting transcription. The LLM powers four agent workflows:

1. **Pre-Visit Intake Agent:** Constructs prompts using patient history from the graph knowledge base + current symptom inputs. GLM generates follow-up questions and produces a structured pre-visit report.
2. **Report Agent (SOAP):** Constructs prompts using the pre-visit report + the transcribed consultation audio (from live recording or uploaded file) or manually typed text. GLM generates a structured SOAP medical report (Subjective, Objective, Assessment, Plan) with medical entity extraction. Adaptive Hermes rules are injected into the prompt context to adapt **documentation style** per doctor preferences — never clinical reasoning. The same agent also produces the bilingual EN/MS patient summary at finalize time via an `update_summary` tool call (so post-visit summary is not a separate process).
3. **Evaluator Agent (AI Safety Review):** Runs synchronously after the Report agent emits a SOAP draft. Phase 1 runs five validators in parallel (drug-allergy, drug-drug interaction, pregnancy safety, dose, completeness) backed by Cypher queries over the Neo4j drug knowledge graph; Phase 2 runs a single LLM hallucination check sequentially. Findings are persisted to `evaluator_findings` and surfaced in the doctor's review panel; CRITICAL findings must be acknowledged before approve/finalize (soft-block at three enforcement points: `ReportReviewAppService.approve`, `SoapWriteAppService.finalize`, and the agent's `/agents/report/finalize`).
4. **Hermes Adaptive Rule Engine:** Captures doctor edit diffs and proposes documentation-style rules scoped to a doctor + condition context. Rules are stored as `AdaptiveRule` nodes in Neo4j and injected into the Report agent's prompt at generation time. Rules **must never** alter diagnosis, treatment, dosing, contraindications, or red-flag thresholds.

2.1.3. Dependency Diagram

The dependency and interaction flow between system components:

a. Prompt Construction: Each agent (Pre-Visit, Visit, Post-Visit) constructs prompts by combining: (1) system instructions defining the agent's role, (2) patient context retrieved from the graph knowledge base via multi-hop graph queries, (3) learned adaptive rules relevant to the current doctor/context, and (4) the user's current input (symptoms, consultation notes, etc.).

b. Context Window Contents: Patient demographics, visit history, known allergies, current medications, symptom descriptions, pre-visit report (for Visit agent), medical report (for Post-Visit agent), and applicable adaptive rules.

c. Response Parsing: GLM responses are parsed by LangGraph into structured JSON objects (e.g., medical report sections in SOAP format, medication lists, follow-up questions). These structured outputs are validated and passed back to Spring Boot via HTTP response.

d. Token Management: Input truncation is enforced at the Python agent layer. Patient history is summarized if it exceeds token limits. Conversation context is windowed for multi-turn symptom intake.

e. Major API Calls:

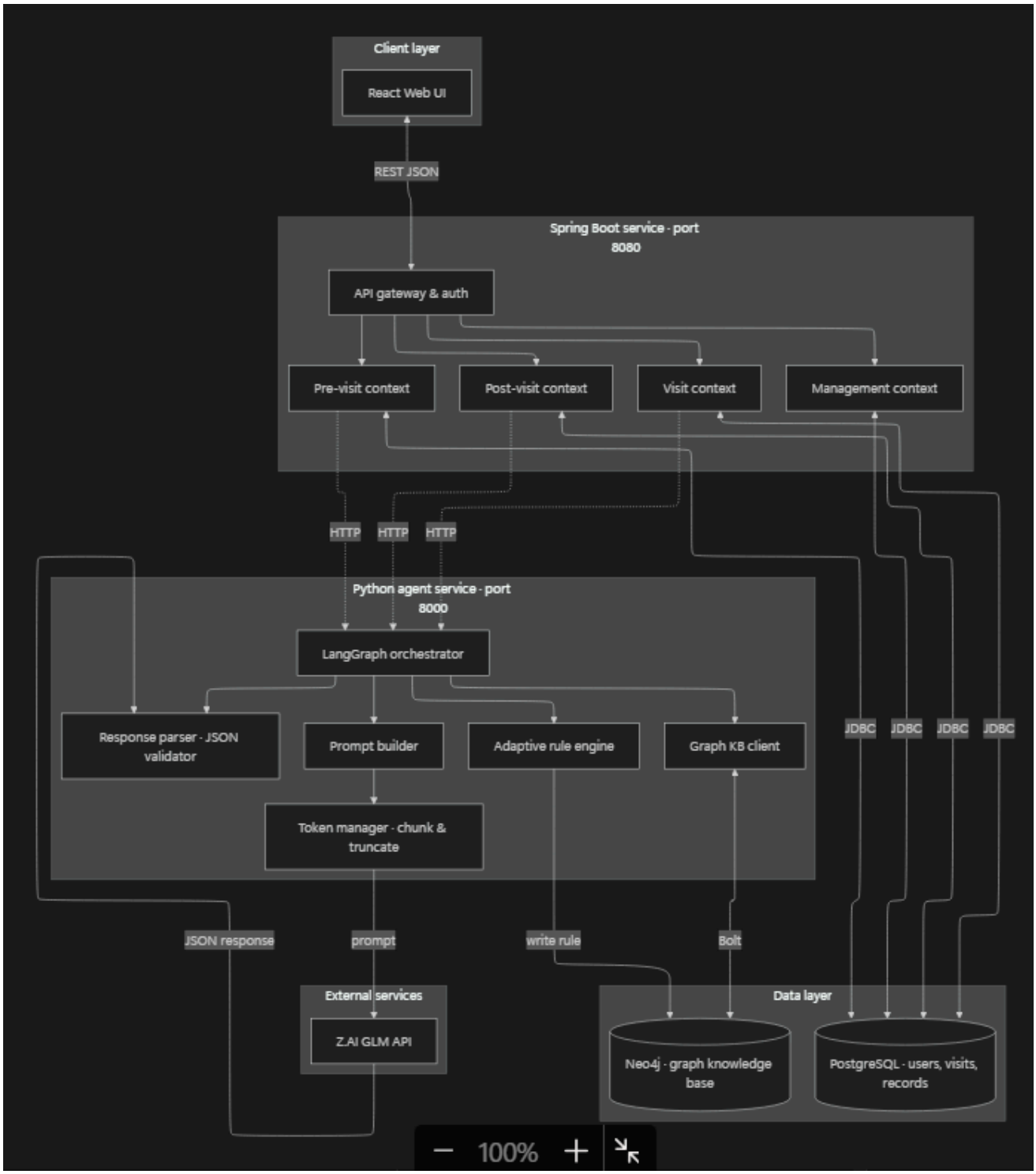
- React Web UI → Spring Boot API Gateway (REST/JSON, port 8080)
- Spring Boot Intake Service → Python Pre-Visit Agent (HTTP, port 8000)
- Spring Boot Consultation Service → Speech-to-Text service (HTTPS, external, for audio transcription)
- Spring Boot Consultation Service → Python Visit Agent (HTTP, port 8000)
- Spring Boot Summary Service → Python Post-Visit Agent (HTTP, port 8000)
- Python Agents → Z.AI GLM API (HTTPS, external)
- Python Agents → Neo4j (graph knowledge base, Bolt protocol)
- Spring Boot Services → PostgreSQL (JDBC)

f. Frontend-Backend-Service-Database Interaction:

- Frontend (React) communicates only with Spring Boot (REST API)
- Spring Boot handles auth, validation, and business logic, then delegates AI tasks to Python agent service via internal HTTP calls
- Python agent service queries the graph knowledge base (Neo4j) for patient context, calls GLM for reasoning, and returns structured outputs to Spring Boot
- Spring Boot persists results to PostgreSQL and returns responses to frontend

g. Distributed Components: The system runs as two independently deployable services (Spring Boot on port 8080, Python FastAPI on port 8000) sharing PostgreSQL and Neo4j databases. In production, these would be containerized (Docker) and deployed behind a reverse proxy.

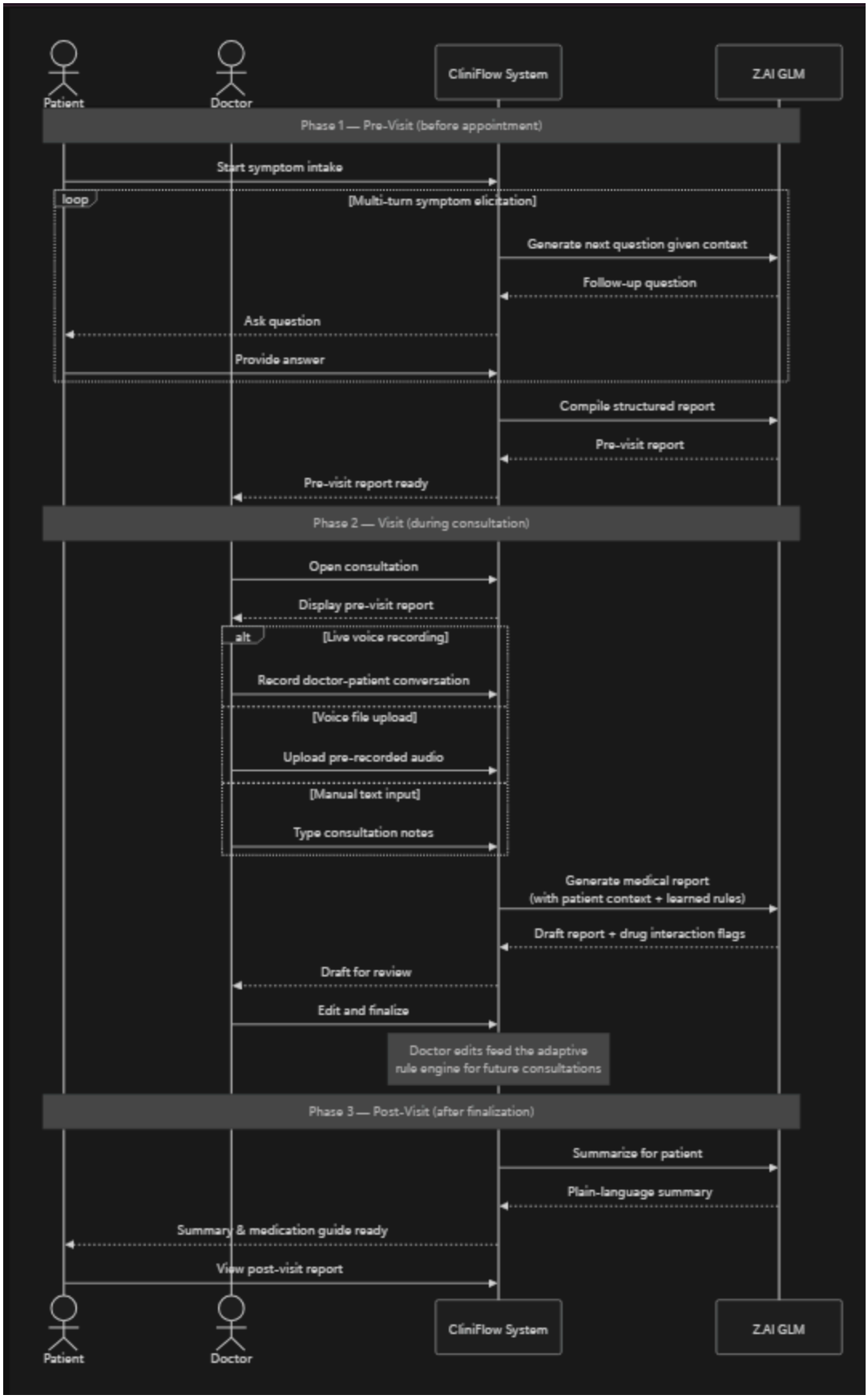
Dependency Diagram:



2.2.2. Sequence Diagram

The high-level sequence below shows the complete business process across all three phases, including the multi-turn intake loop in Phase 1, the three input modes in Phase 2, and the adaptive rule feedback loop that lets the system learn from every consultation. This is the bird's-eye view at the business process level; detailed per-phase sequences with API endpoints, databases, and internal components are in Section 2.4 Design per Phase.

High-Level Business Process Sequence:


Patient
Doctor
CliniFlow System
ZAI GLM
Phase 1 — Pre-Visit (before appointment)
Start symptom intake
loop
[Multi-turn symptom elicitation]
Generate next question given context
Follow-up question
Ask question
Provide answer
Compile structured report
Pre-visit report
Pre-visit report ready
Phase 2 — Visit (during consultation)
Open consultation
Display pre-visit report
alt
[Live voice recording]
Record doctor-patient conversation
[Voice file upload]
Upload pre-recorded audio
[Manual text input]
Type consultation notes
Generate medical report
(with patient context + learned rules)
Draft report + drug interaction flags
Draft for review
Edit and finalize
Doctor edits feed the adaptive
rule engine for future consultations
Phase 3 — Post-Visit (after finalization)
Summarize for patient
Plain-language summary
Summary & medication guide ready
View post-visit report
Patient
Doctor
CliniFlow System
ZAI GLM

What this diagram communicates:

- *Intake is conversational, not a form.* The loop in Phase 1 shows GLM driving the dialogue — it decides when enough information has been gathered.
- *The doctor has choice in how to capture the consultation.* The `alt / else` block in Phase 2 makes the three input modes explicit at the business level.
- *The system learns from every visit.* The Note after Phase 2 highlights that doctor edits are not discarded — they become training signal that improves future reports.
- *GLM is load-bearing across all three phases.* Every phase contains at least one GLM call. Remove GLM and the system degenerates to a CRUD app.

2.2. Technological Stack

1. **Frontend:** Next.js 14 (App Router, React 18, TypeScript) — responsive web application with four role-based portals (Patient, Doctor, Staff/Receptionist, Clinic Admin/Owner). Aurora-glass dark theme.
2. **Backend (Business Logic):** Spring Boot 3.3 (Java 21) — RESTful API, DDD bounded contexts (patient, user, visit, schedule, clinic), auth/RBAC, patient record CRUD, scheduling, WhatsApp notification outbox drainer, Neo4j projection drainer.
3. **Backend (AI Orchestration):** FastAPI (Python 3.12) + LangGraph — four agents (Pre-Visit Intake, Report, Evaluator, plus the Post-Visit summary tool inside Report), GLM client, Whisper STT client, graph KB client, Hermes adaptive rule engine.
4. **Relational Database:** Supabase-hosted PostgreSQL (via pgbouncer transaction-mode pooler) — users, patients, doctors, staff_profiles, patient_clinical_profiles, visits, pre/medical/post-visit reports, medications, evaluator_findings, agent_turns, audit_log, schedule_template, appointment_slots, appointments, schedule_day_overrides, notification_outbox, whatsapp_message_log, neo4j_projection_outbox.
5. **Graph Database:** Neo4j 5.20 Community — patient knowledge graph (Patient/Visit/Symptom/Diagnosis/Medication/Allergy/Condition/AdaptiveRule) plus drug knowledge graph (Drug/DrugClass/PregnancyCategory/DoseRule with `INTERACTS_WITH`, `BELONGS_TO`, `PREGNANCY_CATEGORY`, `HAS_DOSE_RULE` edges). Schema applied idempotently at FastAPI startup from `agent/app/graph/schema.py::apply_schema`. Drug-knowledge bundle seeded from `agent/app/graph/seed/drug_knowledge.json` (39 Malaysian primary-care drugs, 9 DDIs, 6 dose rules).
6. **LLM Provider:** OpenAI-compatible endpoint pointed at **Z.AI GLM 5.1** (`ilmu-glm-5.1`, `api.ilmu.ai/v1`) in both dev and prod. The provider is pluggable but no longer points at OpenAI for chat.
7. **Speech-to-Text:** OpenAI Whisper (`whisper-1`), called by the Python agent. Independent of the LLM provider.
8. **Notifications:** WhatsApp via configurable provider — `stub` (dev), `twilio`, or `meta-cloud`. Implemented as a Postgres-backed outbox (`notification_outbox`)

with a Spring `@Scheduled` drainer; per-message audit in `whatsapp_message_log` storing only a SHA-256 hash of the recipient phone (never plaintext).

9. **Resilience:** Resilience4j circuit breakers (`llm`, `stt`) on every Spring → Python agent call, with timeouts (8s for LLM, 30s for STT) and correlation-ID propagation via `X-Correlation-ID`.
10. **Deployment:** Docker Compose — five services (frontend, backend, agent, neo4j, nginx). Nginx reverse proxy on port 80 with `proxy_read_timeout 300s` for slow LLM paths and `client_max_body_size 25MB` for audio uploads. The Python agent is internal-only (no `ports:` mapping).

2.3. Key Data Flows

2.3.1. Data Flow Diagram (DFD)

External Entities: Patient, Doctor, Clinic Staff, Clinic Admin

Processes:

- P1: Symptom Intake Process — receives patient symptoms, queries graph KB for history, calls GLM, generates structured pre-visit report
- P2: Consultation Documentation Process — receives doctor's consultation input (live voice recording, uploaded audio, or text), transcribes voice via STT, queries graph KB, applies adaptive rules, calls GLM, generates structured medical report
- P3: Post-Visit Summary Process — receives finalized medical report, calls GLM, generates patient-friendly summary
- P4: Adaptive Rule Learning Process — receives doctor edit diffs, analyzes patterns, proposes and stores rules in graph KB
- P5: User & Access Management — handles authentication, role-based access control, force-password-reset, role/active toggling, PDPA audit log viewer
- P6: AI Safety Evaluator Process — receives a SOAP draft, runs Phase 1 (allergy / DDI / pregnancy / dose / completeness validators in parallel via Cypher) and Phase 2 (LLM hallucination check) against the drug knowledge graph and patient context, persists findings, soft-blocks finalize on unacknowledged CRITICALs
- P7: Scheduling & Booking Process — generates appointment slots from a doctor's recurring template (with day overrides and closures), books patient appointments, handles check-in / cancellation / no-show, walk-in registration
- P8: Notification Process — enqueues WhatsApp events (appointment booked / cancelled, SOAP finalized meds & follow-up reminder) into the outbox; drainer dequeues, renders via Twilio or Meta Cloud template, logs to `whatsapp_message_log`, retries with exponential backoff

Data Stores:

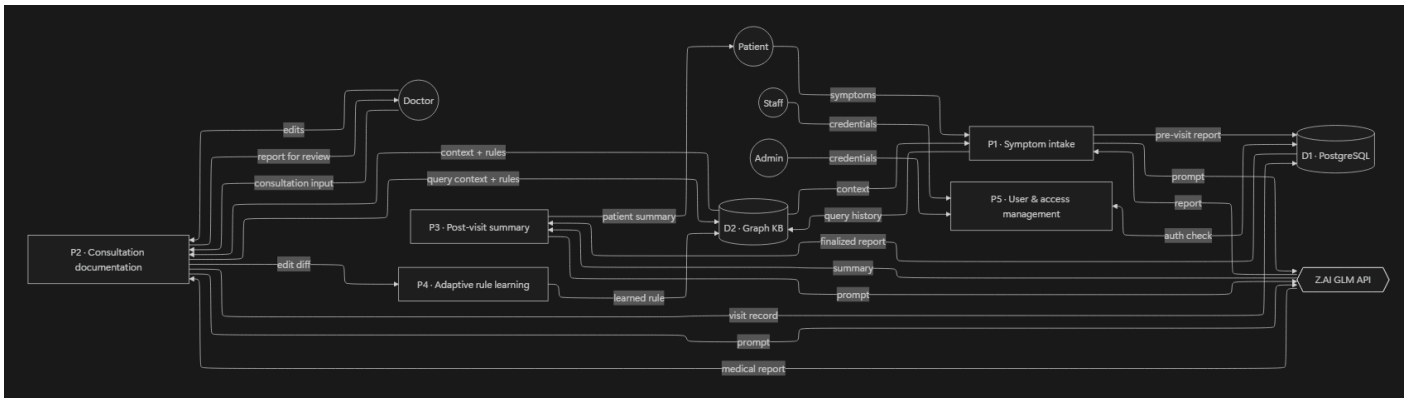
- D1: PostgreSQL — patient records, visit records, user accounts
- D2: Neo4j (graph knowledge base) — patient knowledge graph, adaptive rules

Key Flows:

- Patient → P1: symptom text input → P1 → D2: query patient history → P1 → GLM: generate follow-up questions and report → P1 → D1: store pre-visit report
- Doctor → P2: consultation input (voice or text) → P2 → STT: transcribe voice → P2 → D2: query context + rules → P2 → GLM: generate medical report → P2 → Doctor: review → P2 → D1: persist visit
- P2 → P4: edit diff → P4 → D2: store learned rule
- P3 → Patient: simplified summary with medication instructions

No black holes exist — all processes have both inputs and outputs. No miracles exist — all outputs trace back to data inputs.

Data Flow Diagram:



2.3.2. Normalized Database Schema

PostgreSQL (Relational — Supabase-hosted, 3NF):

Migrations live in `backend/src/main/resources/db/migration/` as reference-only SQL (V1 through V14). Flyway is NOT used (incompatible with Supabase pgbouncer transaction-mode pooler — see post-mortem `2026-04-22-backend-boot-and-schema.md`). Schema is applied manually via the Supabase SQL editor or `supabase db push`. JPA runs with `ddl-auto: none`. Note: V2 has two files in the repo (`V2__seed_dev_users.sql` and `V2__evaluator_and_drug_validation.sql`) — a known naming collision; both have been applied and the order is captured in commit history.

Table	Key Columns	Relationships / Notes
users	id (PK), email (citext, UK), password_hash, role (PATIENT/DOCTOR/STAFF/ADMIN), full_name, is_active, consent_given_at, gmt_create, gmt_modified	1:N with visits (as doctor); V4 adds consent_given_at for PDPA
patients	id (PK), user_id (FK users), national_id_ciphertext (bytea, app-encrypted), national_id_fingerprint (HMAC-SHA256, UK), full_name, date_of_birth, gender, phone, email, gmt_create, gmt_modified	1:N with visits
visits	id (PK), patient_id (FK), doctor_id (FK), status (SCHEDULED/IN_PROGRESS/FINALIZED/CANCELLED), started_at, finalized_at, report_draft (jsonb), report_confidence_flags (jsonb), gmt_create, gmt_modified	Aggregate root. V6 adds report_draft/confidence_flags for Report Agent streaming state.
pre_visit_reports	id (PK), visit_id (FK, UK), structured (jsonb), source (PATIENT/AI/STAFF), gmt_create, gmt_modified	1:1 with visits
medical_reports	id (PK), visit_id (FK, UK), subjective, objective, assessment, plan, ai_draft_hash (sha256), is_finalized, finalized_by (FK users), finalized_at, preview_approved_at, summary_en, summary_ms, gmt_create, gmt_modified	1:1 with visits. V8 adds preview_approved_at + bilingual summary columns — patient-facing summaries are written HERE on finalize, not to post_visit_summaries. CHECK constraint: is_finalized ⇒ finalized_by + finalized_at set.
post_visit_summaries	id (PK), visit_id (FK, UK), patient_summary, summary_en, summary_ms, gmt_create, gmt_modified	LEGACY. New finalize writes to medical_reports.summary_en/summary_ms; this table is only read as a

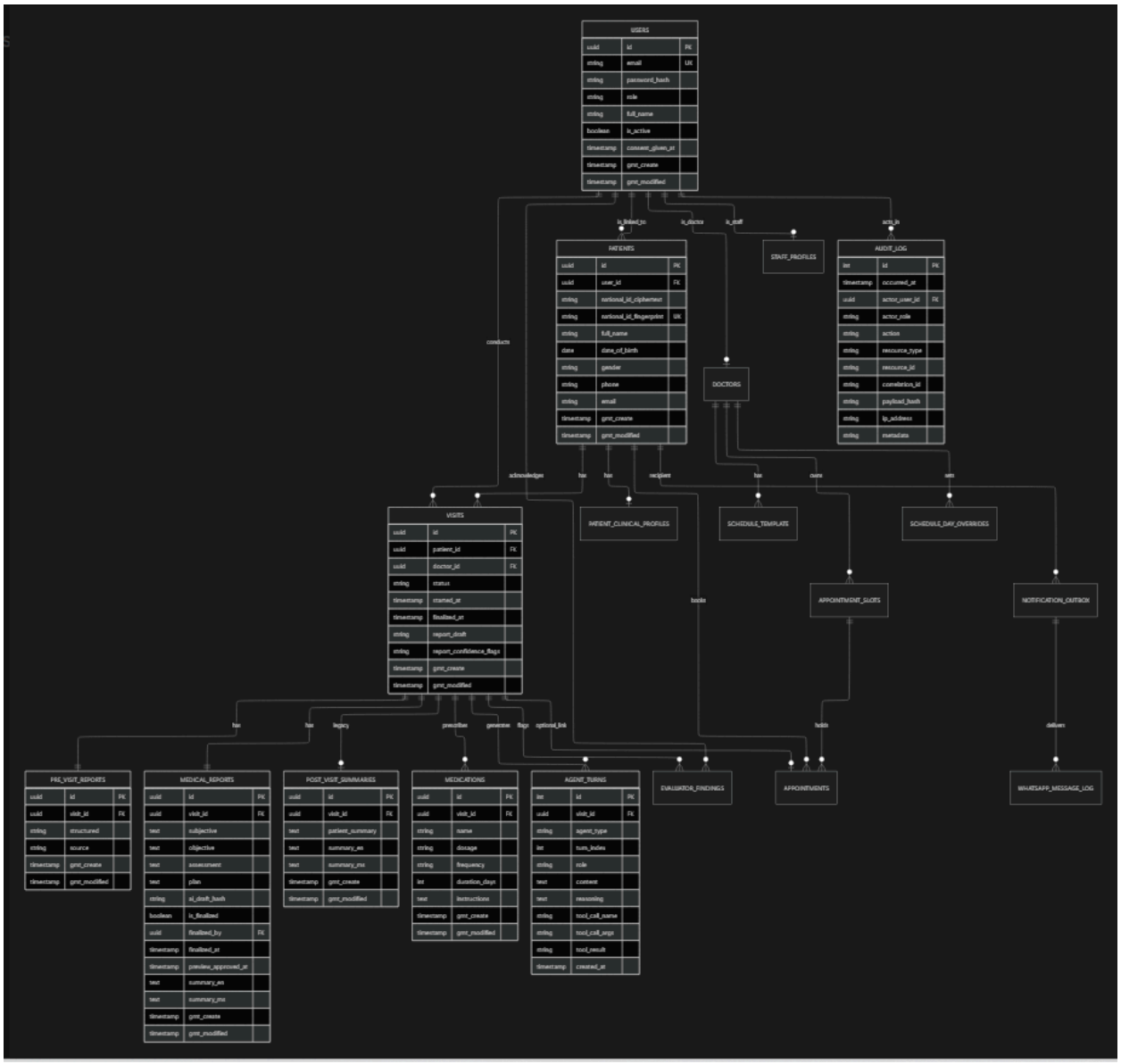
		fallback for pre-refactor visits.
medications	id (PK), visit_id (FK), name, dosage, frequency, duration_days (int), instructions (text), gmt_create, gmt_modified	N:1 with visits. Written by ReportReviewAppService.finalize() from finalizedReport.plan.medications.
agent_turns	id (bigserial, PK), visit_id (FK), agent_type (pre_visit/report), turn_index (int), role (system/user/assistant/tool), content, reasoning, tool_call_name, tool_call_args (jsonb), tool_result (jsonb), created_at. UNIQUE(visit_id, agent_type, turn_index)	V5. Append-only agent conversation log — DB triggers block UPDATE/DELETE. V7 adds AFTER INSERT trigger that writes an audit_log row for each turn (PDPA).
audit_log	id (bigserial, PK), occurred_at, actor_user_id (FK users), actor_role, action (READ/CREATE/UPDATE/DELETE/LOGIN/EXPORT), resource_type, resource_id, correlation_id, payload_hash, ip_address (inet), metadata (jsonb)	PDPA append-only. DB triggers raise exception on any UPDATE or DELETE — never mutate from application code, always INSERT. V13 adds an action index for admin-portal log viewer.
doctors	id (PK), user_id (FK users, UK), mmc_number (UK), specialty, signature_image_url, license_expiry, clinic_id, gmt_create, gmt_modified	V9. Doctor-specific extension of users; one row per DOCTOR-role user. MMC# is the Malaysian Medical Council registration number.

staff_profiles	id (PK), user_id (FK users, UK), employee_id (UK), department / notes, gmt_create, gmt_modified	V9. Staff-specific extension of users; one row per STAFF-role user.
patient_clinical_profiles	id (PK), patient_id (FK patients, UK), weight_kg, height_cm, drug_allergies (jsonb), chronic_conditions (jsonb), regular_medications (jsonb), pregnancy_status (NOT_APPLICABLE/NOT_PREGNANT/PREGNANT/POSTPARTUM_LACTATING/UNKNOWN), pregnancy_edd, completeness_state, _updated_at, _source columns	V9. Source-tracked clinical profile feeding the evaluator's pregnancy / dose / allergy validators. CHECK constraint: PREGNANT ⇒ EDD required.
evaluator_findings	id (PK), visit_id (FK visits), category (DRUG_ALLERGY/DDI/PREGNANCY/DOSE/HALLUCINATION/COMPLETENESS), severity (CRITICAL/HIGH/MEDIUM/LOW), field_path, message, details (jsonb), acknowledged_at, acknowledged_by (FK users), acknowledgement_reason, superseded_at, gmt_create, gmt_modified	V2. Evaluator output. Soft-block gate uses partial index (visit_id) WHERE severity='CRITICAL' AND acknowledged_at IS NULL AND superseded_at IS NULL. Re-evaluation supersedes prior findings atomically under a pg_advisory_xact_lock(visit_id).
schedule_template	id (PK), doctor_id (FK doctors), effective_from (date), slot_minutes (10/15/20/30), weekly_hours (jsonb), cancel_lead_hours (default 2), generation_horizon_days (default 28). UNIQUE(doctor_id, effective_from)	V11. Doctor's recurring weekly schedule used to generate appointment_slots.
appointment_slots	id (PK), doctor_id (FK doctors), start_at, end_at, status (AVAILABLE/BOOKED/BLOCKED/CLOSED). UNIQUE(doctor_id, start_at), CHECK end_at > start_at	V11. Concrete time slots derived from template + day overrides. Partial index (doctor_id,

		start_at) WHERE status='AVAILABLE' for fast booking queries.
appointments	id (PK), slot_id (FK appointment_slots), patient_id (FK patients), visit_id (FK visits), appointment_type (NEW_SYMPTOM/FOLLOW_UP), parent_visit_id, status (BOOKED/CHECKED_IN/CANCELLED/COMPLETED/NO_SHOW), checked_in_at, cancel_reason, cancelled_at, cancelled_by	V11 + V12. Patient-side booking layered on top of slots. Partial UNIQUE on slot_id and visit_id where status='BOOKED' to enforce single-active-booking.
schedule_day_overrides	id (PK), doctor_id (FK doctors), override_date, override_type (DAY_CLOSED/WINDOW_BLOCKED), window_start (time), window_end (time), reason, created_by (FK users)	V11. Per-day exceptions to the recurring template (closures, blocked windows). CHECK: WINDOW_BLOCKED requires both window_start and window_end.
notification_outbox	id (PK), event_type (APPOINTMENT_BOOKED/APPOINTMENT_CANCELLED/SOAP_FINALIZED_MEDS/SOAP_FINALIZED_FOLLOW UP), channel (WHATSAPP), template_id, recipient_patient_id (FK patients), payload (jsonb), idempotency_key (UK), status (PENDING/SENDING/SENT/FAILED/SKIPPED_NO_CONSENT), attempts, next_attempt_at, last_error, sent_at	V11. Outbox pattern; drained by OutboxDrainerScheduler (@Scheduled every 30s, max 5 attempts, exponential backoff, stuck-in-SENDING reaper after 2 min).
whatsapp_message_log	id (PK), outbox_id (FK notification_outbox), twilio_sid / meta_message_id, to_phone_hash (char(64), SHA-256 of phone — never plaintext), template_id, rendered_locale, delivery_status (QUEUED/SENT/DELIVERED/READ/FAILED/UNDELIVERED), provider_error_code	V11. Per-message delivery audit. Phone number is hashed for PDPA compliance — plaintext lives only

		on the patient row and the active outbox payload.
neo4j_projection_outbox	id (bigserial, PK), aggregate_id (uuid), operation, payload (jsonb), status (PENDING/IN_FLIGHT/COMPLETED/FAILED), attempts, next_attempt_at, last_error, enqueued_at, completed_at	V9. Projection pattern — Spring writes a row when a clinical aggregate changes, a drainer pushes to Neo4j idempotently. Decouples graph projection latency from the request path.
patients (V11 extension)	+whatsapp_consent_at, whatsapp_consent_version, +pregnancy_status, pregnancy_trimester, weight_kg, height_cm (V2 evaluator columns)	Consent for WhatsApp messaging is required before notifications fire (status SKIPPED_NO_CONSENT otherwise). Pregnancy / weight / height feed evaluator validators directly.

ERD — PostgreSQL schema (3NF):



Graph Knowledge Base (Neo4j):

Neo4j hosts two co-resident graphs in the same database — the **patient knowledge graph** (per-patient clinical context) and the **drug knowledge graph** (clinic-wide pharmaceutical reference data used by the evaluator). Schema is applied idempotently from `agent/app/graph/schema.py::apply_schema` on FastAPI startup.

Patient Knowledge Graph nodes: Patient, Doctor, Visit, Symptom, Diagnosis, Medication, Allergy, Condition, AdaptiveRule.

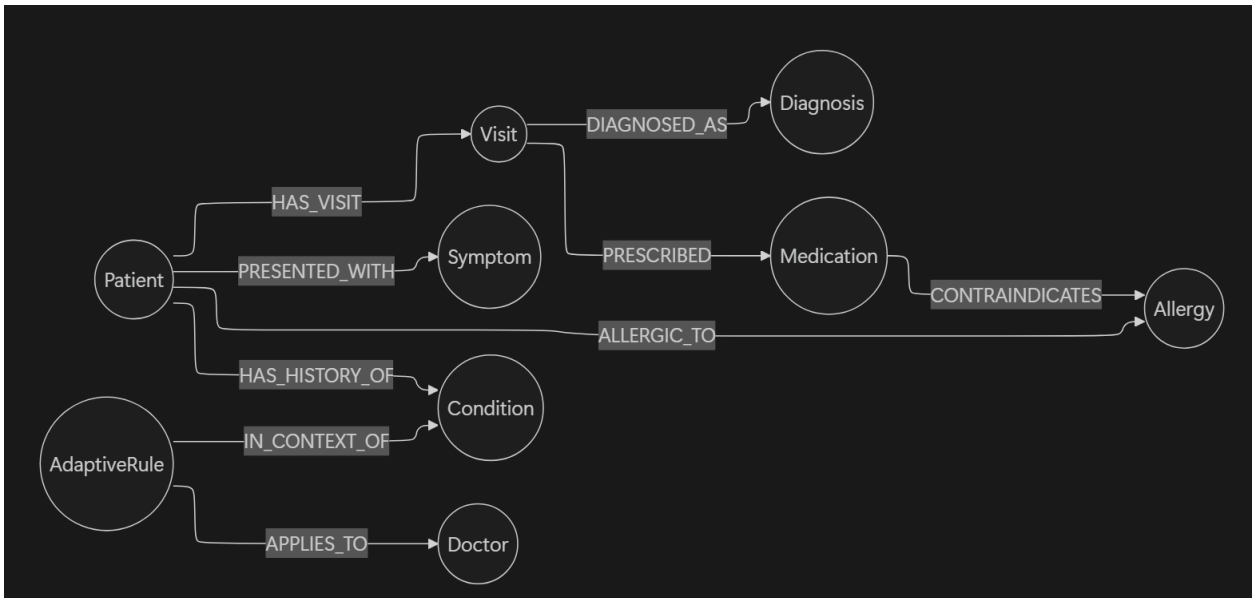
Patient KG relationships: `(Patient)-[:PRESENTED_WITH]->(Symptom)`, `(Visit)-[:DIAGNOSED_AS]->(Diagnosis)`, `(Visit)-[:PRESCRIBED]->(Medication)`, `(Medication)-[:CONTRAINDICATES]->(Allergy)`, `(Patient)-[:HAS_HISTORY_OF]->(Condition)`, `(Patient)-[:ALLERGIC_TO]->(Allergy)`, `(Patient)-[:HAS_VISIT]->(Visit)`, `(Doctor)-[:CONDUCTED]->(Visit)`, `(AdaptiveRule)-[:APPLIES_TO]->(Doctor)`, `(AdaptiveRule)-[:IN_CONTEXT_OF]->(Condition)`. Inferred edges (Graphify pattern) carry a `confidence` property in [0.0, 1.0] and a `source` location.

Drug Knowledge Graph nodes: Drug (name unique, lowercase), DrugClass (e.g., NSAID, beta-blocker), PregnancyCategory (codes A/B/C/D/X), DoseRule (id unique; min/max age, weight band, route, frequency_pattern, min/max dose, min/max daily dose).

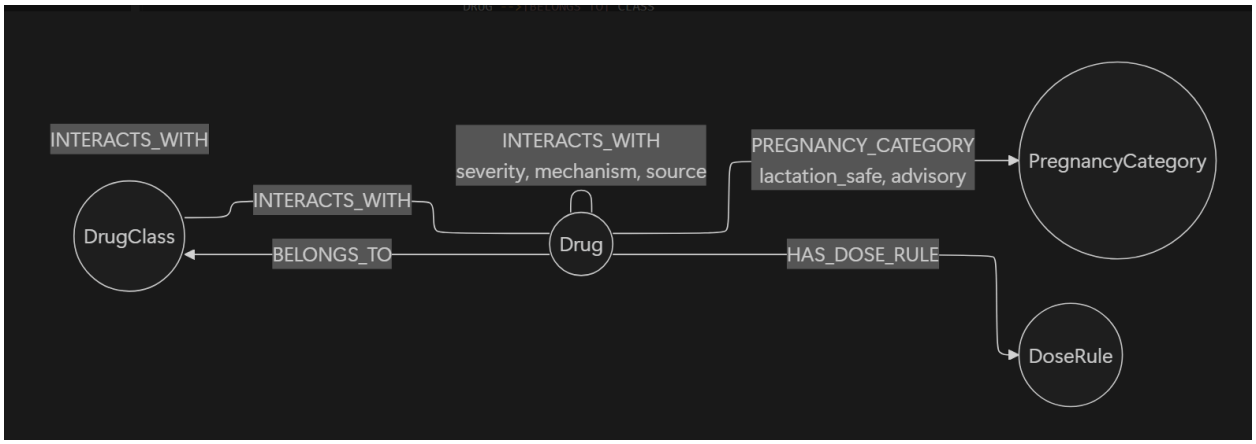
Drug KG relationships: `(Drug)-[:BELONGS_TO]->(DrugClass)`, `(Drug)-[:INTERACTS_WITH {severity: MAJOR|MODERATE|MINOR, mechanism, source}]->(Drug)` (seeded symmetrically), `(DrugClass)-[:INTERACTS_WITH ...]->(DrugClass|Drug)`, `(Drug)-[:PREGNANCY_CATEGORY {lactation_safe, advisory}]->(PregnancyCategory)`, `(Drug)-[:HAS_DOSE_RULE]->(DoseRule)`. Seeded from `agent/app/graph/seed/drug_knowledge.json` — 39 Malaysian primary-care drugs, 9 DDIs, 6 dose rules — applied idempotently via `apply_drug_knowledge()` on agent boot.

Secondary indexes: `Visit ON (patient_id)`, `Visit ON (doctor_id)`, `AdaptiveRule ON (doctor_id)`.

Graph Knowledge Base Schema Diagram:



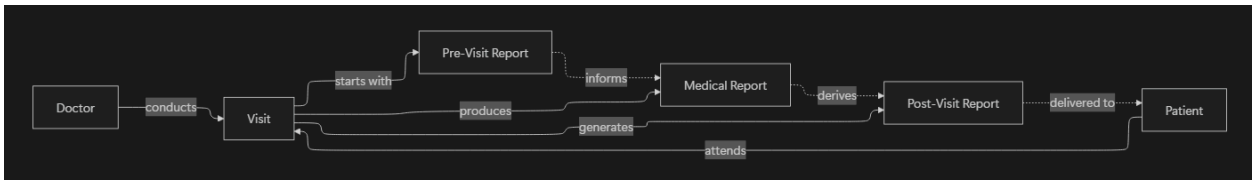
Drug Knowledge Graph Schema Diagram:



The drug graph is queried by the evaluator validators (DDI, allergy, pregnancy, dose) using Cypher modules in `agent/app/graph/queries/`. Multi-hop DDI lookup follows three paths: drug↔drug, drug↔class, class↔class.

2.3.3. Domain Relationship Map (Business View)

The graph schema above shows the *storage* view — every clinical concept is a node for query flexibility. At the *domain* level, the model is simpler: Visit is the aggregate root that owns its three phase artifacts, and clinical entities live either within the visit artifact that produces them or at the Patient level when they persist across visits.



2.4. Detail Design

The end-to-end clinical workflow is split into three phases, each owned by a bounded context and powered by a dedicated AI agent. Sections 2.4.1–2.4.3 describe each phase's data flow end-to-end; Sections 2.4.4–2.4.5 zoom into the internal architecture of the two Python agents that power those phases (Pre-Visit Intake Agent and Report Agent — the Post-Visit summary is produced by a tool call from the Report Agent, not a separate agent process).

2.4.1. Pre-Visit Phase Design

Context: Pre-Visit bounded context (Spring Boot) + Pre-Visit Agent (Python)

Actor: Patient

Trigger: Patient logs in before their appointment and starts symptom intake

Agent Prompt Composition:

- *System instructions:* agent role ("medical symptom intake assistant"), output schema, tone guidelines
- *Patient context from graph KB:* known allergies, chronic conditions, most recent visit summary (if any)
- *Conversation state:* symptoms reported so far in this session
- *Current input:* patient's latest message

Data Read:

- Graph KB — patient node, allergy and condition edges, prior visit summaries
- PostgreSQL — patient demographics

Data Written:

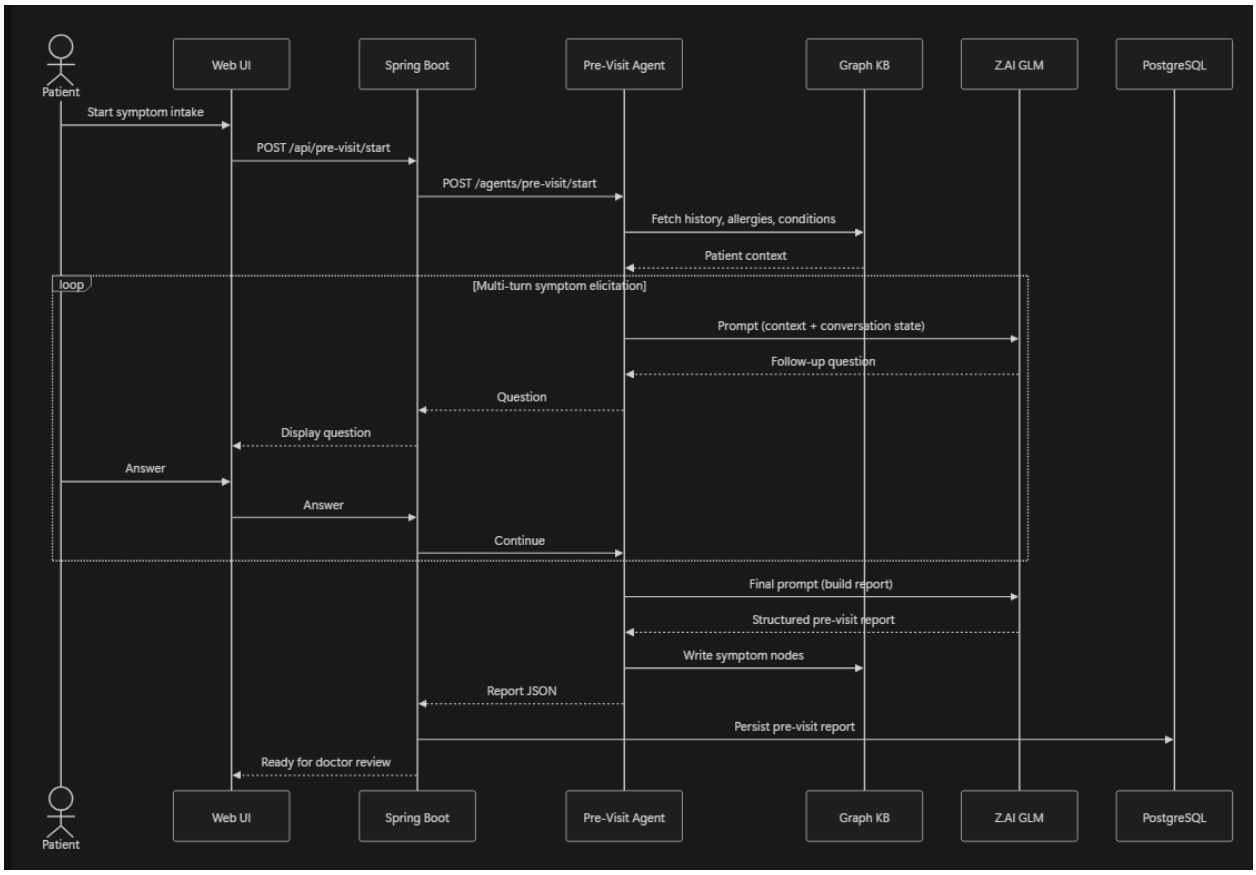
- PostgreSQL — pre-visit report (symptom summary, structured data JSON, generated timestamp)
- Graph KB — new symptom nodes attached to the patient

GLM Output Structure:

- Either: next follow-up question (string) with reasoning (why this question)
- Or: terminal signal with final structured pre-visit report (symptoms, duration, severity, relevant history flags)

Key Design Decision: The agent controls when intake is complete, not a fixed script. GLM decides "do I have enough information?" on each turn. This is multi-step reasoning, not template filling.

Sequence Diagram — Pre-Visit Flow:



2.4.2. Visiting Phase Design

Context: Visit bounded context (Spring Boot) + Visit Agent (Python)

Actor: Doctor (with the patient present)

Trigger: Doctor opens the consultation for a patient whose pre-visit report is ready

Input Modes: The doctor has three ways to capture the consultation, exposed as three tabs on the Consultation panel:

1. *Text tab (default)* — doctor types or pastes consultation notes directly. Fastest path and the fallback when audio tooling is unavailable.
2. *Voice tab — file upload* — doctor drags-and-drops (or picks) a pre-recorded audio file (MP3/WAV/M4A/WebM/FLAC/OGG, up to 25MB). Used when the doctor recorded on a separate device such as a phone at the bedside.
3. *Live tab — in-browser recording* — doctor clicks the record button to capture the consultation live via the browser's MediaRecorder API. A red pulsing timer shows elapsed time. On stop, the WebM blob is posted to the backend.

Both voice inputs (file upload and live recording) post to `POST /api/visits/{id}/audio` on Spring Boot, which forwards the multipart payload to the Python agent's `/agents/stt/transcribe` endpoint, which in turn calls OpenAI Whisper (`whisper-1`). The transcript is returned synchronously and auto-populates the Text tab, where the doctor can review and edit before clicking Generate report. Spring multipart limits are set to 25MB to match the Nginx `client_max_body_size`.

Agent Prompt Composition:

- *System instructions:* agent role ("clinical documentation assistant"), output schema using the SOAP format (Subjective, Objective, Assessment, Plan), medical entity extraction rules
- *Patient context from graph KB:* allergies, current medications, chronic conditions, recent diagnoses (multi-hop query)
- *Pre-visit report:* structured symptom summary from Phase 1
- *Adaptive rules:* formatting and content rules learned from this doctor's prior edits
- *Consultation input:* either the transcribed audio or the manually typed text

Data Read:

- PostgreSQL — visit record, pre-visit report, doctor profile
- Graph KB — patient context (multi-hop), applicable adaptive rules
- Speech-to-Text service — transcript produced from recorded or uploaded audio

Data Written:

- PostgreSQL — medical report with four SOAP-format sections, medication entries, finalized flag, reference to the source audio file (if voice)
- Graph KB — new diagnosis, prescription, and symptom nodes linked to the visit; doctor edit diffs for adaptive rule analysis

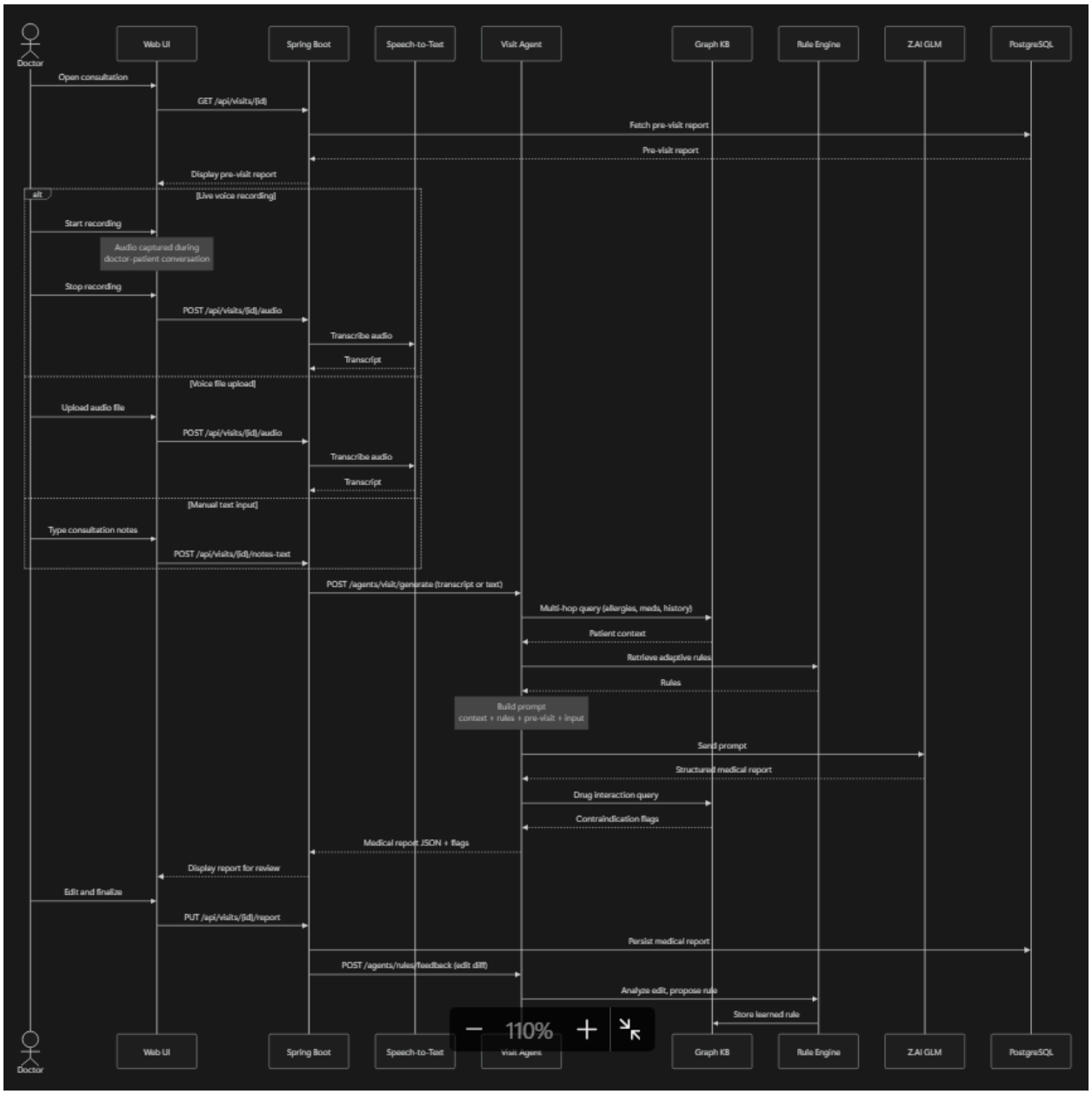
GLM Output Structure:

- Structured medical report with four sections: Subjective, Objective, Assessment, Plan
- List of extracted medications with dosage fields
- List of extracted diagnoses
- Missing-information flags (if any required fields could not be inferred from the consultation)

Key Design Decision: The doctor must review and finalize the report before it is persisted as the official record. The AI output is a draft, not a clinical decision. Every edit feeds the adaptive rule engine, which proposes new rules (subject to a confidence threshold) to apply in subsequent consultations.

Drug Interaction Check Sub-Flow: When a new prescription is extracted, the Visit Agent runs a separate graph query: `Prescription → contraindicated_by → Allergy` and `Prescription → interacts_with → ActiveMedication`. Any conflicts are surfaced to the doctor before the report is finalized.

Sequence Diagram — Visit Consultation Flow:



2.4.3. Post-Visit Phase Design

Context: Post-Visit bounded context (Spring Boot) + Post-Visit Agent (Python)

Actor: Patient (reads), system (generates)

Trigger: Doctor finalizes the medical report, emitting a `VisitFinalized` event

Agent Prompt Composition:

- *System instructions:* agent role ("patient-friendly summary writer"), output schema, reading-level target (layperson)
- *Finalized medical report:* full four SOAP-format sections
- *Medication list:* structured prescriptions
- *Patient context (optional):* age, language preference

Data Read:

- PostgreSQL — finalized medical report, medication list, patient demographics

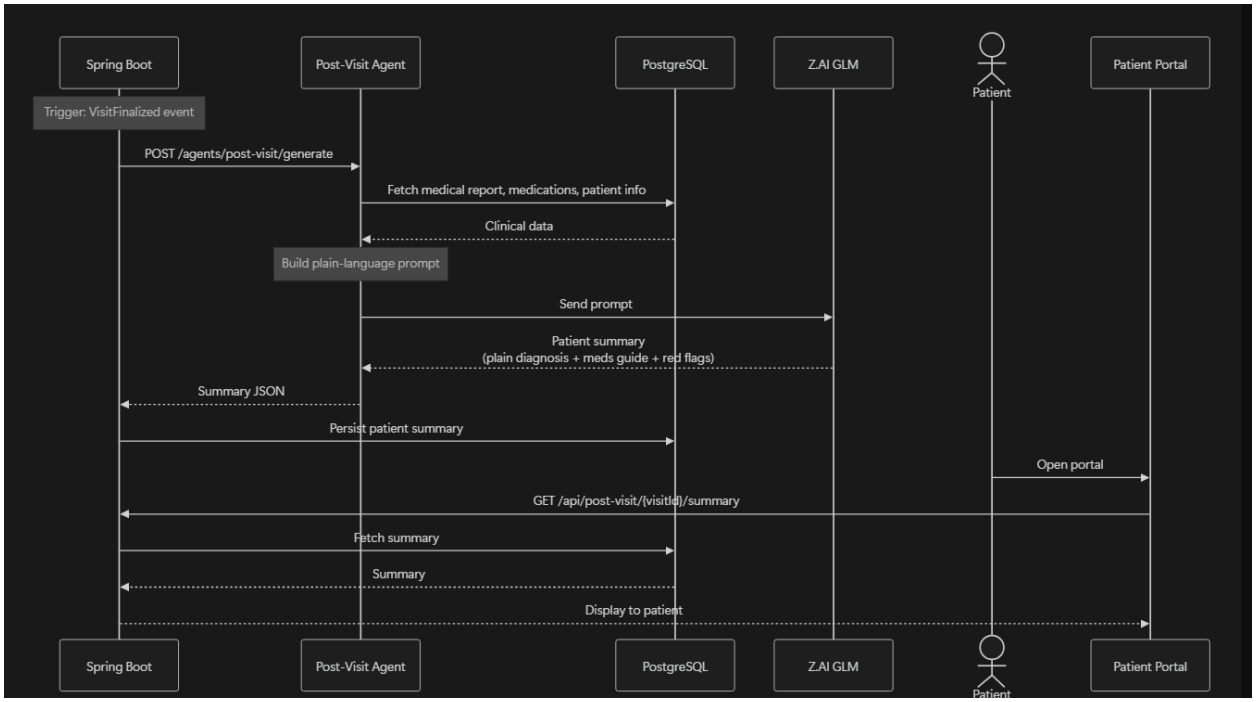
Data Written:

- PostgreSQL — patient summary (plain-language diagnosis, care instructions, red flags), structured medication guide

GLM Output Structure:

- Plain-language diagnosis explanation
- Structured medication guide (what, when, how long, why, with-food/empty-stomach notes)
- Red-flag symptoms (when to seek urgent care)
- Follow-up guidance

Key Design Decision: Output is generated once and cached — no need to re-run on every patient portal view. The medical report is the source of truth; the summary is a derived view. If the medical report is ever amended, the summary is regenerated.



2.4.4. Pre-Visit Agent Design

Purpose: Conversational symptom-intake agent. Collects chief complaint, duration, associated symptoms, allergies, and current meds — *confirming* facts already known from the graph KB rather than re-asking.

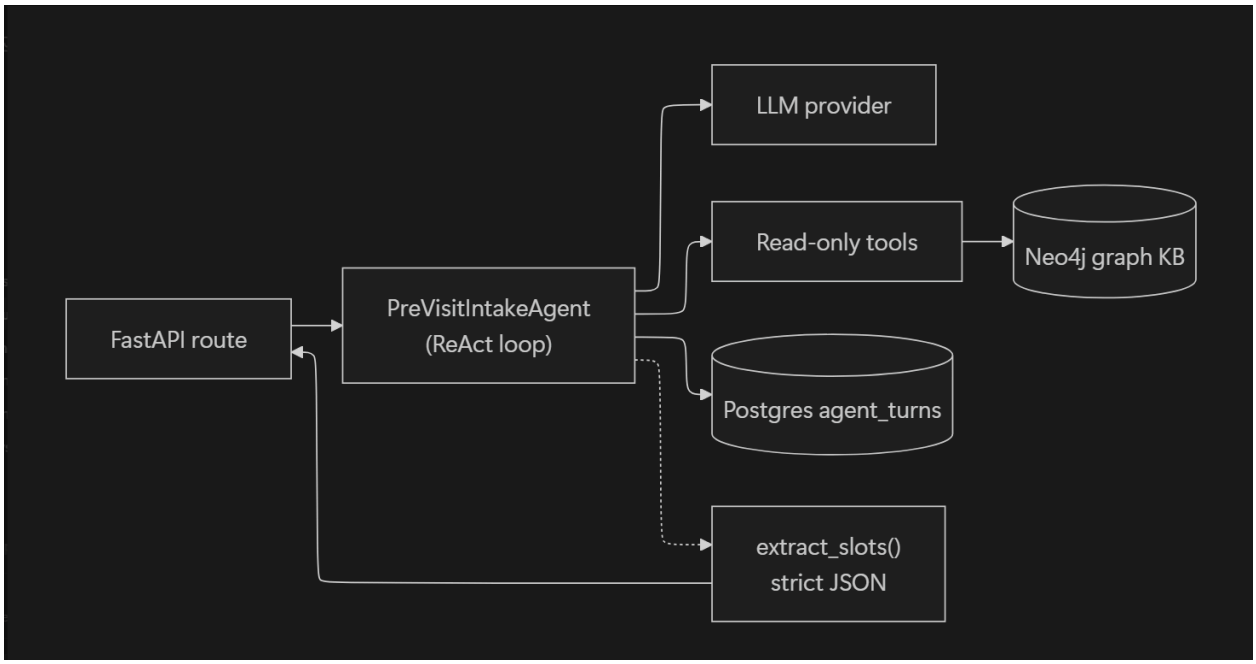
Class: `PreVisitIntakeAgent(BaseAgent)` · `agent_type = "pre_visit"`

Tools (all read-only):

Tool	Purpose
get_patient_context	Fetch demographics, allergies, active meds, chronic conditions from Neo4j
get_visit_history	Fetch recent finalized visits for the patient
emit_reasoning	Stream a short reasoning delta to the UI (non-visible turn)

Output paths: (1) a conversational stream of follow-up questions rendered in the patient portal chat, and (2) a post-hoc `extract_slots()` LLM call that returns a strict-JSON `PreVisitSlots` model. A parse failure in extraction returns an empty slots object rather than breaking the chat.

Pre-Visit Agent — High-Level Architecture:



Key design decisions:

- The agent, not a fixed script, decides when intake is complete.
- Slot extraction is decoupled from the chat loop — a bad JSON parse cannot corrupt patient-facing output.
- Read-only: persistence is the orchestrator's responsibility.

2.4.5. Report Agent Design

Purpose: Transforms a consultation transcript (Text / Voice upload / Live recording) into a structured SOAP report, and on finalize produces the bilingual patient summary. Unlike the Pre-Visit Agent, this agent **writes** — it persists the draft via `update_soap_draft`.

Class: `ReportAgent(BaseAgent)` · `agent_type = "report"`

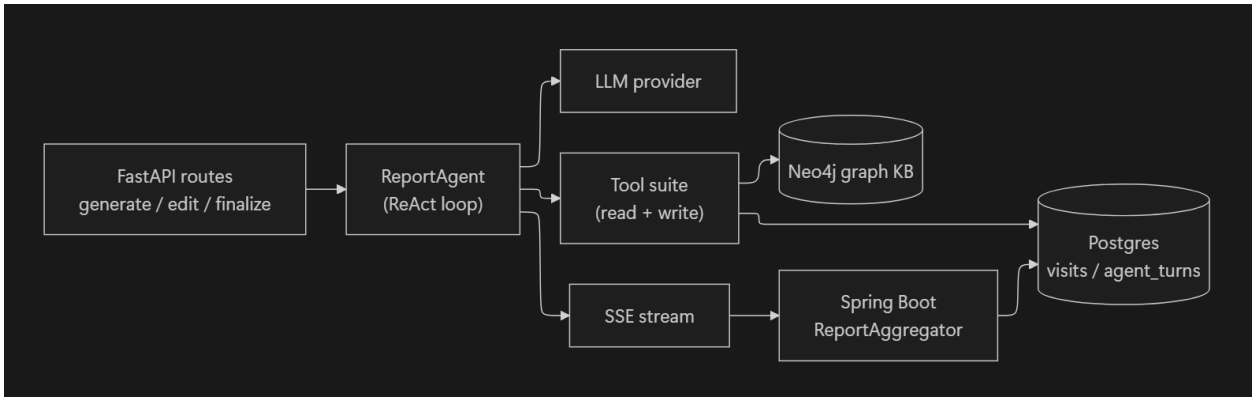
Three modes (same ReAct loop, different input): *Generate* from transcript → *Edit* from doctor chat instruction (current draft is injected into the prompt) → *Finalize* produces bilingual EN/MS summary. Spring Boot owns the visit status transition; the agent only produces drafts + summaries.

Tool allowlist:

Tool	Purpose	Reads / Writes
get_visit_history	Recent visits for the patient	Read: Postgres + Neo4j
clinical_dictionary_extract	Extract ICD-10 codes and clinical entities from transcript	Read-only LLM sub-call
update_soap_draft	Persist structured MedicalReport to visits.report_draft jsonb + visits.report_confidence_flags	Write: Postgres
record_inferred_edge	Record an inferred graph relationship with 0.0–1.0 confidence (Graphify pattern)	Write: Neo4j
emit_reasoning	Stream reasoning delta to UI	Side-channel SSE only

Two safeguards in the prompt: the `HERMES_FENCE` keeps adaptive rules in documentation-style territory only (never diagnosis, dosing, or red-flag thresholds), and the `EDIT PROCESS` block forbids `ask_doctor_clarification` on a doctor edit request.

Report Agent — High-Level Architecture:



Key design decisions:

- Doctor-in-the-loop is non-negotiable — the agent produces a draft; only an explicit finalize by a real doctor promotes it to the patient-facing record.
- State lives in Postgres, not agent memory — the draft is persisted on every `update_soap_draft` call, so a dropped connection never loses the working draft.
- Post-Visit is not a separate agent — the bilingual summary is a tool call the Report Agent makes at finalize time, keeping it in the same transaction as the report write.
- After the drafter completes, the orchestrator invokes the Evaluator Agent (§2.4.6) and emits an SSE `evaluator.done` event so the doctor's review panel surfaces findings before approve/finalize.

2.4.6. Evaluator Agent Design

Purpose: AI safety review of every SOAP draft. Surfaces drug-safety, dose-range, pregnancy, completeness, and hallucination findings to the doctor and soft-blocks finalize on unacknowledged CRITICAL findings.

Class: `EvaluatorAgent` (standalone orchestrator — does **not** extend `BaseAgent`; this is a deterministic validator pipeline, not a ReAct loop).

Validators (six categories, mapped 1:1 to `evaluator_findings.category`):

Validator	Type	Source	Severity Mapping
DDI	Cypher	Drug KG :INTERACTS_WITH edges (drug↔drug, drug↔class, class↔class)	MAJOR→CRITICAL, MODERATE→HIGH, MINOR→LOW
DOSE	Cypher + Python parsing	:DoseRule filtered by age + weight + route; parses dose ("500mg", "5 mg/kg") and frequency (BD, TDS, QID)	over_max_dose / over_max_daily / under_min→CRITICAL; no_rule→MEDIUM; missing_weight→MEDIUM; frequency_unparseable→LOW

HALLUCINATION	LLM	Single GLM call classifying every clinical claim as SUPPORTED / CONTEXTUAL / INFERRED / UNSUPPORTED	UNSUPPORTED→HIGH; 8s timeout, graceful fallback to empty list on parse/timeout error

Two-Phase Execution:

1. *Phase 1 (parallel)* — allergy, DDI, pregnancy, dose, completeness run via `asyncio.gather(return_exceptions=True)` with a per-validator soft cap of 1.5s. Failed or over-cap validators are marked unavailable but do not tank the run.
2. *Phase 2 (sequential)* — hallucination runs after Phase 1 (single LLM call, 8s soft timeout).

Persistence: Findings are inserted and prior non-superseded findings are atomically superseded under `pg_advisory_xact_lock(visit_id)`. Concurrent re-evaluations cannot interleave finding sets.

Soft-block at three enforcement points (defense in depth):

1. `ReportReviewAppService.approve()` — returns 409 if any unacknowledged CRITICAL finding exists.
2. `SoapWriteAppService.finalize()` — returns 409 before transitioning the visit to FINALIZED.
3. Python agent `POST /agents/report/finalize` — same 409 gate, in case Spring is bypassed.

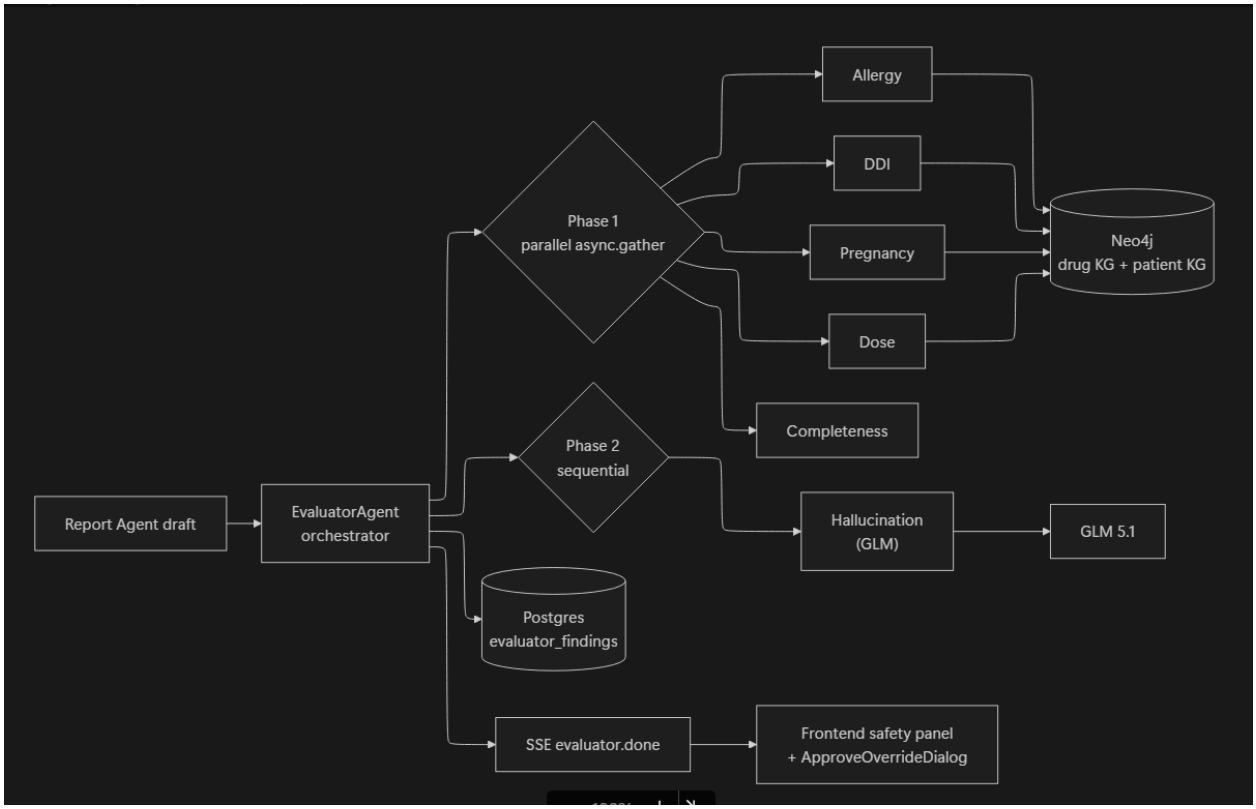
The doctor may override CRITICALs **only** via the frontend `ApproveOverrideDialog`, which writes a per-finding ack-with-reason row (≤255 chars, audit `UPDATE / evaluator_finding_ack`) before retrying the gated mutation. Auto-acknowledgement is forbidden; reasons are required.

API surface:

- Spring (frontend-facing): `GET /api/visits/{id}/findings`, `POST /api/visits/{id}/findings/{findingId}/acknowledge`, `POST /api/visits/{id}/re-evaluate`.
- Agent (internal, service-token only): `GET /agents/evaluator/findings/{visit_id}`, `POST /agents/evaluator/re-evaluate`. The Report agent's generate / clarify / edit /

finalize endpoints all chain into the evaluator after producing or mutating a draft and emit `evaluator.done` (or `evaluator.error`) as an SSE event.

Evaluator Agent — High-Level Architecture:



Key design decisions:

- The evaluator is a child entity of the Visit aggregate, not a new aggregate — lifecycle bound to the visit.
- Validators degrade independently: a Cypher timeout marks one validator unavailable, the other five still produce findings.
- CRITICAL severity never auto-relaxes — Hermes is documentation-style only; clinical reasoning never adapts to override patterns.
- Pregnancy validator is skipped (not deferred) when status is not explicitly known, so the audit trail never implies pregnancy state from absence.

2.4.7. Scheduling & Booking Design

Context: Schedule bounded context (Spring Boot only — no agent involvement).

Actors: Doctor (template owner), Staff (overrides + walk-ins), Patient (booking).

Trigger model:

- Doctor edits `schedule_template` (recurring weekly hours + slot length) → `SlotGenerateDomainService` regenerates `appointment_slots` for the rolling horizon (default 28 days).
- Staff sets a `schedule_day_override` (DAY_CLOSED or WINDOW_BLOCKED) → affected slots transition to BLOCKED/CLOSED, in-flight bookings flagged.
- Patient books via `POST /api/appointments` → atomic CAS on slot status (AVAILABLE→BOOKED), creates appointment + enqueues `APPOINTMENT_BOOKED` notification.
- Staff checks in → `appointments.status → CHECKED_IN`, `checked_in_at` set; the patient appears on the doctor's queue.
- A nightly `@Scheduled` cron extends the slot horizon and reaps stuck-in-SENDING notifications.

Concurrency: Single-active-booking enforced via partial UNIQUE indexes on `appointments(slot_id) WHERE status='BOOKED'` and `appointments(visit_id) WHERE status='BOOKED'`. Race-safe.

2.4.8. Staff Portal Design

Routes: `/staff` (today's queue), `/staff/schedule`, `/staff/patients`.

Capabilities (in scope): today's waiting list with pre-visit status indicators, walk-in registration (creates a patient + optionally a login account), check-in.

Explicitly out of scope (per spec): editing patient demographics, resetting patient passwords, NRIC search, print-queue / call-next display.

2.4.9. Admin Portal Design

Routes: `/admin`, `/admin/users`, `/admin/users/{id}` (drawer), `/admin/analytics`, `/admin/audit`.

Capabilities:

- *User management:* create user (PATIENT/DOCTOR/STAFF/ADMIN), drawer view, role change, active toggle, force password reset (writes `users.must_change_password=true`).
- *Analytics:* four KPIs (total patients, total appointments, today's appointments, 30-day finalized visits) plus a 30-day appointments sparkline.
- *Audit log viewer:* read-only paginated `audit_log` with filters by action, resource type, and date range. Append-only is enforced at the DB layer; admin cannot mutate.

Explicitly out of scope: audit CSV export, suspicious-activity preset filters, doctor-breakdown analytics, evaluator-finding dashboard, clinic profile settings, notification settings, holiday calendar, PDPA data-subject export, audit retention notice.

---

3. Functional Requirements & Scope

This section highlights the core boundaries of the project, enabling focus on a high-impact MVP to showcase the technical feasibility of CliniFlow AI.

3.1. Minimum Viable Product

The MVP features are organised by clinical phase (pre-visit → visit → post-visit) and by operational portal (scheduling, staff, admin, notifications). Section 3.1.0 lists hard cross-cutting invariants that gate every feature below.

3.1.0. Hard Cross-Cutting Invariants (never compromise)

These are the non-negotiable safety and privacy rules every feature in 3.1.1–3.1.7 inherits. They are enforced in code, schema triggers, and reviews.

1. **Doctor-in-the-loop.** Every AI-generated clinical artifact (SOAP, evaluator finding override, bilingual summary) is a draft until an explicit doctor finalize. The UI visibly distinguishes AI draft from human-confirmed.
2. **Hermes adaptive rules are documentation-style only.** Learned rules may change phrasing, section ordering, abbreviations — never diagnosis, treatment, dosing, contraindications, or red-flag thresholds.
3. **PDPA append-only audit.** `audit_log` and `agent_turns` have BEFORE UPDATE / BEFORE DELETE triggers that raise. Application code only INSERTs. Every CREATE / UPDATE / DELETE of patient data writes a row.
4. **Server-side identity from JWT.** Every controller acting on per-patient data derives `patient_id` from the JWT principal (`PatientReadAppService.findByUserId(claims.userId())`). Path-parameter IDs require an explicit ownership check. Never hardcode UUIDs. (Driven by 2026-04-30 cross-patient PHI leak post-mortem — hardcoded UUID in `PreVisitController` contaminated 65 visits.)
5. **Frontend talks to Spring Boot only.** Next.js never calls the Python agent or Neo4j directly, never uses the Supabase JS client for clinical data. RBAC and audit are enforced centrally in Spring.
6. **Evaluator soft-block at three enforcement points.** Unacknowledged CRITICAL findings (DDI, allergy, dose, pregnancy) gate `ReportReviewAppService.approve`, `SoapWriteAppService.finalize`, and `/agents/report/finalize`. Override only via `ApproveOverrideDialog` with a doctor-supplied reason; never auto-acknowledge.

3.1.1. Pre-Visit Phase Features

#	Feature	Description
1.1	AI Symptom Intake Agent	Patients describe symptoms via a conversational chatbot. GLM dynamically generates follow-up questions based on prior responses, driving multi-turn symptom elicitation until sufficient information is captured.
1.2	Patient History Retrieval	Before generating follow-up questions, the Pre-Visit Agent queries the graph knowledge base for the patient's known allergies, chronic conditions, and prior visit summaries. This context shapes the questions asked and prevents repeat data entry.
1.3	Structured Pre-Visit Report Generation	The agent transforms the conversational intake into a structured report with symptom summary, severity indicators, duration, and relevant history flags. The doctor reviews this before the consultation.

3.1.2. Visiting Phase Features

#	Feature	Description
2.1	Live Voice Recording of Consultation	Doctor clicks Record to capture the live doctor-patient conversation on the spot. When the consultation ends, the audio is sent to a Speech-to-Text service and the transcript becomes the primary input to the Visit Agent. This is the primary path — doctors no longer type during consultation.
2.2	Alternative Input Modes (Voice Upload & Text)	For situations where live recording isn't practical, doctors can upload a pre-recorded audio file or type consultation notes manually. All three input modes converge on the same agent pipeline.
2.3	AI Medical Report Generation	The Visit Agent calls GLM to generate a structured medical report from the consultation input. The report follows the SOAP format (Subjective, Objective, Assessment, Plan) and includes extracted clinical entities.
2.4	Medical Entity Extraction	The agent identifies and structures key clinical entities from the consultation — symptoms with duration, diagnoses, prescribed medications with dosage, and proposed follow-up actions.

2.5	Missing Information Detection	The agent flags incomplete clinical information (e.g., prescribed medication without duration, assessment without supporting objective findings) and prompts the doctor to complete them before finalization.
2.6	Drug Interaction Check (Graph KB Multi-Hop Query)	When a new prescription is added, the system traverses the patient's knowledge graph to detect contraindications with existing medications or known allergies. This is the hero demo for the graph reasoning capability.
2.7	Doctor Review & Edit Workflow	The doctor reviews, edits, and finalizes the AI-generated medical report. The UI highlights AI-generated content versus doctor edits. Once finalized, the report is locked and persisted.
2.8	Adaptive Rule Learning (Hermes)	Every doctor edit is captured as a feedback signal. The rule engine analyzes edit patterns and proposes documentation-style rules (phrasing, section ordering, abbreviations) injected into future prompts. Read side built; write side currently NotImplementedError and deferred. Scope is documentation only — never clinical reasoning.
2.9	AI Safety Review (Evaluator)	After the SOAP draft is produced, the Evaluator Agent runs six validators (drug-allergy, DDI, pregnancy, dose, completeness, hallucination) against the drug knowledge graph and patient context. Findings appear in an "AI Safety Review" panel with severity (CRITICAL / HIGH / MEDIUM / LOW) and a per-finding field_path.
2.10	Override-with-Reason Flow	CRITICAL findings soft-block approve and finalize. The doctor opens ApproveOverrideDialog, supplies a free-text reason (≤255 chars) per finding, and submits. The acknowledgement writes to evaluator_findings.acknowledgement_reason and an audit row (UPDATE / evaluator_finding_ack); finalize then proceeds.

3.1.3. Post-Visit Phase Features

#	Feature	Description
3.1	Patient-Friendly Summary Generation	The Post-Visit Agent transforms the finalized medical report into plain-language patient instructions. Diagnosis is explained without jargon, and care instructions are simplified.

3.2	Structured Medication Guide	The agent produces a medication list with clear dosage, frequency, duration, and special instructions (e.g., "take with food") in language the patient can follow.
3.3	Red Flag & Follow-Up Guidance	The summary includes red-flag symptoms (when to seek urgent care) and follow-up appointment information, which the patient accesses via the patient portal.
3.4	Bilingual EN/MS Summary	At finalize, the Report Agent produces both English and Bahasa Malaysia versions of the patient summary in a single LLM call. Stored in medical_reports.summary_en and medical_reports.summary_ms. Patient portal renders the version matching the patient's preferred_language.
3.5	E-Prescription View	Patient portal displays a read-only e-prescription drawn from medications rows finalized with the visit. PDF download stub (full PDF generation deferred). View access is audited (READ / e_prescription).

3.1.4. Scheduling & Booking Features

#	Feature	Description	4.1	Doctor schedule template	Doctor configures recurring weekly hours, slot length (10/15/20/30 min), and horizon (default 28 days). Editing the template regenerates appointment_slots.
4.2	Day overrides	Staff can mark a day closed or block a specific window with a reason. Affected slots transition; existing bookings flagged for re-contact.	4.3	Patient appointment booking	Patient books an AVAILABLE slot via the portal; atomic CAS prevents double-booking. Optional follow-up booking links a parent_visit_id.
4.4	Check-in / cancellation / no-show	Status transitions enforced server-side. Cancellation captures cancel_reason and cancelled_by. No-show is	4.5	Horizon extender cron	Nightly @Scheduled job rolls the slot horizon forward and reaps stuck-in-SENDING notifications.

		staff-driven and writes audit.			

3.1.5. Staff Portal Features

#	Feature	Description	5.1	Today's waiting list	Real-time list of patients arriving today with arrival time, slot, and pre-visit-intake status indicator (pending / submitted / none).
5.2	Walk-in registration	Modal to register a walk-in patient (demographics) and optionally create a login account in one step.	5.3	Check-in	One-click check-in flips the appointment to CHECKED_IN and adds the patient to the doctor's queue.

3.1.6. Admin Portal Features

#	Feature	Description	6.1	User management	Create users (PATIENT / DOCTOR / STAFF / ADMIN). Drawer view per user with role change, active toggle, and force-password-reset (sets must_change_password).
6.2	Analytics KPIs	Four KPI cards: total patients, total appointments, today's appointments, 30-day finalized visits. Plus a 30-day appointments sparkline.	6.3	PDPA audit log viewer	Read-only paginated audit_log with filters by action, resource type, and date range. DB triggers guarantee append-only.

3.1.7. Notification Features

#	Feature	Description

7.2	Drainer + retry	`OutboxDrainerScheduler` polls every 30s, exponential backoff on transient failures, max 5 attempts, 2-minute reaper for stuck-in-SENDING rows.
7.4	Consent gate	Patients without `whatsapp_consent_at` set are skipped (status SKIPPED_NO_CONSENT). Per-message audit logs only the SHA-256 hash of the recipient phone, never plaintext.

3.2. Non-Functional Requirements (NFRs)

Quality	Requirements	Implementation
Scalability	CliniFlow AI must handle concurrent consultations during peak clinic hours (morning rush).	Spring Boot thread pool configuration. Python async agent service with FastAPI. Connection pooling for PostgreSQL and Neo4j.
Reliability	AI-generated medical reports must always go through doctor review before finalization. Failed GLM API calls must not corrupt patient records.	Mandatory doctor confirmation step (US-D04). Database transactions with rollback on API failure. Graceful degradation: if GLM is unavailable, doctors can still enter notes manually.
Maintainability	Each bounded context (Pre-Visit, Visit, Post-Visit, Management) is independently modifiable. Agent logic is separated from business logic.	DDD package structure in Spring Boot. Python agent service with per-agent modules. Clear HTTP contract between Java and Python services.

Token Latency	GLM API calls must return a response within 5s under normal load (p95). Pre-visit intake follow-up questions must feel conversational (<3s).	Timeout of 8s for async API calls. Loading state displayed to user while awaiting response. Prompt length controlled via input truncation and history summarization.
Cost Efficiency	Average token cost per consultation session must remain within budget threshold.	Fixed-length system prompts. Patient history summarized before injection. Adaptive rules are short structured entries, not free-text. Repeated graph KB queries cached for the session duration.
Data Privacy (PDPA)	Must comply with Malaysia's Personal Data Protection Act 2010 for patient health information.	Encryption at rest (Supabase) and in transit (TLS). Role-based access control via Spring Security @PreAuthorize. Consent mechanisms (consent_given_at, whatsapp_consent_at). Append-only audit_log with DB triggers blocking UPDATE/DELETE.
Server-side identity	Every controller acting on per-patient data must derive identity from the authenticated principal, not from request parameters. Path-parameter IDs require explicit ownership checks.	JWT principal claims, PatientReadAppService.findByUserId(claims.userId()), ownership-check pattern documented in docs/details/identity-and-authz.md. Driven by 2026-04-30 cross-patient PHI leak post-mortem (65 visits contaminated by hardcoded UUID).

AI safety soft-block	Unacknowledged CRITICAL evaluator findings (DDI, allergy, dose, pregnancy) must block clinical finalize until acknowledged with a reason.	Three enforcement points: ReportReviewAppService.approve, SoapWriteAppService.finalize, /agents/report/finalize. Override only via ApproveOverrideDialog; partial index (visit_id) WHERE severity='CRITICAL' AND acknowledged_at IS NULL AND superseded_at IS NULL makes the gate query an index-only scan.
Resilience	Spring → Python agent calls must degrade gracefully under LLM/STT outages and not cascade.	Resilience4j circuit breakers (llm, stt) with 50% failure threshold, 30s open state, 20-request sliding window. Timeouts: 8s LLM, 30s STT, 300s end-to-end via Nginx. Correlation-ID propagation via X-Correlation-ID.

3.3. Out of Scope / Future Enhancements

Explicitly never building (unless scope changes):

1. E-prescribing with direct pharmacy integration (requires Malaysian Pharmacy Board compliance).
2. Telemedicine / video consultation.
3. Insurance claims processing.
4. Medical imaging analysis (X-ray / MRI / CT — specialized AI domain outside workflow automation).
5. Full EHR system replacement — CliniFlow focuses on workflow automation, not replacing EHRs.
6. Billing and payment processing.
7. Native iOS / Android apps — web-responsive only.
8. Vector database / RAG — reasoning is graph-based (Graphify pattern over Neo4j), not embedding similarity.
9. Multilingual voice transcription with code-switching between English and Malay (English-only STT for MVP).

Deferred (built later, not now):

- Hermes adaptive rule learning — read side built (rules injected into prompt if present); write side raises `NotImplementedError` and is deferred.

- Real-time SSE per-validator progress in the evaluator UI (today the panel polls via synchronous re-evaluate).
- Full e-prescription PDF generation (UI shows a stubbed Download button).
- Doctor-breakdown analytics, holiday calendar, audit CSV export, PDPA data-subject export, DDI / safety findings dashboard, suspicious-activity preset filters.

---

4. Monitor, Evaluation, Assumptions & Dependencies

4.1. Technical Evaluation

4.1.1. Grayscale Rollout & A/B Testing

Rollout follows a four-stage canary pattern with quantitative gates between stages:

Stage	Traffic %	Duration	Advancement Gate
Canary	5%	3 days	Error rate <2%, p95 latency <8s, no P1 incident
Beta	25%	1 week	A/B edit-rate improvement over baseline, no P1 incident
Majority	50%	1 week	Doctor NPS >30, no completeness regression
General	100%	—	—

A/B Testing: runs in parallel during the Beta stage. Treatment group gets adaptive-rules-enabled report generation; control group gets baseline prompts without learned rules. Primary success metric: doctor edit rate on generated reports (percentage of characters changed). Target: ≥20% relative reduction for the treatment group after 2 weeks of rule accumulation. Secondary metric: weekly 1-question doctor satisfaction pulse.

4.1.2. Emergency Rollback & Golden Release

The **Golden Release** is the most recent production image tagged as stable in the container registry (tag format: `cliniflow-api:golden-YYYYMMDD`). A new Golden tag is promoted only after a release has passed the Majority stage (50% traffic, no P1 incidents for 7 days).

Rollback Triggers:

- *Automated:* P1 trigger fires (see Priority Matrix) → monitoring stack posts to a rollback webhook → CI/CD pipeline redeploys the Golden image → typical recovery <5 minutes
- *Manual:* On-call engineer invokes rollback via GitHub Actions `workflow_dispatch`. Used for subjective issues not caught by metrics (e.g., clinically inappropriate AI suggestions flagged by doctors)

Graceful Degradation Paths are preserved regardless of rollback state:

- GLM unavailable → Visit module routes to manual-entry template; CRUD continues to work
- STT unavailable → doctor falls back to text input mode
- Neo4j unavailable → agents operate with PostgreSQL-only context (reduced reasoning quality, system remains functional)

4.1.3. Priority Matrix

Priority	Trigger Condition	Response SLA	Action	Escalation
P0 Catastrophic	Patient data leak, unauthorized access, or data corruption detected. Canonical example: 2026-04-30 cross-patient PHI leak — hardcoded patientId in PreVisitController made every patient see Pat Demo's chart; 65 visits contaminated. See post-mortem 2026-04-30-cross-patient-phi-leak.md.	Immediate	Full system freeze, forensic snapshot via audit_log query, notify stakeholders and legal. Identity must always derive from JWT principal — never from request body/path.	Phone + email + incident war room
P1 Critical	GLM error rate >5% for 5 min, or clinically dangerous content generated	<15 min	Automated rollback to Golden image. Disable AI agents.	PagerDuty / phone
P2 High	Medical report accuracy drops below 70% (edit rate), or p95 latency >10s	<1 hour	Switch to cached/simplified prompts. Alert engineering.	Slack @here

P3 Medium	Adaptive rule proposals rejected by doctor >50% of the time	<24 hours	Pause adaptive rule learning. Review rule generation logic.	Slack channel, daily digest
P4 Low	Minor UI inconsistencies, non-critical feature requests	Next sprint	Log to backlog.	GitHub issue

4.2. Monitoring

4.2.1. Monitoring Stack

CliniFlow AI uses a hosted SaaS-first stack to minimize ops overhead during pilot deployment:

Tool	Purpose	Cost
Grafana Cloud (free tier)	Metrics via Prometheus remote write, logs via Loki, traces via Tempo, unified dashboards	$0 up to 10k series, 50GB logs
Sentry (free tier)	Error tracking with stack traces, release tagging, user session capture	$0 up to 5k events/month
Uptime Robot	External HTTP health checks every 5 min from multi-region probes	$0 up to 50 monitors

Self-hosted fallback: the same stack (Prometheus + Grafana + Loki) can be run via Docker Compose on the same host. This path is chosen only if PDPA review requires all telemetry to remain on-premise.

4.2.2. Four Golden Signals per Service

Each service instruments the same four signals (after Google SRE) so alerting and dashboards are consistent across the Java/Python boundary:

Signal	Spring Boot	Python Agent
Latency	p50/p95/p99 per endpoint via Micrometer + Actuator	p50/p95/p99 per agent via prometheus_client
Traffic	Requests/sec per endpoint	Agent invocations/sec, GLM calls/sec, STT calls/sec

Errors	HTTP 5xx rate, uncaught exceptions	Failed agent runs, GLM errors, STT errors, parse failures
Saturation	JVM heap, DB connection pool, thread pool queue depth	asyncio event loop lag, Neo4j connection pool

4.2.3. Planned Dashboards

Four Grafana dashboards mapped to operational concerns:

1. *System Health* — uptime, error rates, and latency for both services at a glance. First dashboard on-call opens during an incident.
2. *AI Pipeline* — GLM request latency, token usage, cost per consultation, error rate per agent type, STT transcription confidence distribution.
3. *Clinical Quality* — adaptive rule proposal acceptance rate, medical report edit rate trend, missing-info detection hit rate, drug interaction warnings surfaced.
4. *Data Layer* — PostgreSQL query latency by table, Neo4j query latency (including the drug interaction multi-hop query specifically), graph size growth over time.

4.2.4. Alert Routing

Alerts are defined in Grafana Cloud using Prometheus-style rules and routed by priority:

- *P0/P1* → PagerDuty / direct phone call (treated like an on-call shift during pilot)
- *P2* → Slack or Discord channel with @here mention
- *P3* → Channel message without mention + daily digest email
- *P4* → Auto-opened GitHub issue

Concrete alert examples:

- `glm_error_rate > 5% for 5min` → P1
- `p95_latency_seconds{service="visit-agent"} > 10 for 10min` → P2
- `rule_acceptance_rate < 50% over 24h` → P3

4.3. Assumptions

1. Target clinics have reliable internet connectivity for web-based access.
2. Doctors and staff have basic digital literacy and can interact with a web application.
3. Patients have access to a smartphone or computer to interact with the symptom intake chatbot.
4. AI-generated clinical notes always require doctor review and confirmation before finalization — the AI assists but does not replace clinical judgment.

5. Bilingual EN/MS patient summaries are produced at finalize; STT remains English-only for MVP. Code-switched voice is out of scope.
6. **Validated:** Z.AI GLM 5.1 (`ilmu-glm-5.1`, `api.ilmu.ai/v1`) exposes an OpenAI-compatible chat endpoint and is the LLM in dev and prod.
7. Voice transcription accuracy of ≥90% is achievable for Malaysian-accented English using OpenAI Whisper (`whisper-1`). The doctor can always correct the transcript before the agent generates the report.
8. The Malaysian primary-care drug knowledge bundle (`drug_knowledge.json` — 39 drugs, 9 DDIs, 6 dose rules) is sufficient breadth for MVP; clinical pharmacist sign-off cadence and update process are open questions.
9. PDPA review of free-text `evaluator_findings.acknowledgement_reason` content is pending — reasons may contain incidental PHI and need a redaction policy before bulk aggregation.

4.4. External Dependencies

Tools	Purpose	Risks
Z.AI GLM API	Core LLM reasoning engine — handles prompt inference, multi-step reasoning, and generating structured clinical output for all three agents	High — if GLM API rate-limited or unavailable, core AI features fail. Mitigation: graceful degradation to manual entry mode; abstract GLM behind internal API layer for potential provider switch.
Neo4j Community Edition	Graph database for the graph knowledge base — stores patient knowledge graph and adaptive rules	Medium — if Neo4j unavailable, agents lose patient context. Mitigation: cache recent patient context in-memory; system still functions with reduced context quality.
PostgreSQL	Relational database for core application data (users, patients, visits, records)	Medium — critical for all CRUD operations. Mitigation: standard database backup and recovery procedures.
OpenAI Whisper (whisper-1)	Transcribes live voice recordings and uploaded audio from consultations before the Report Agent processes them. Independent of the LLM provider.	Medium — if STT unavailable or low-quality, doctors fall back to manual text input. Mitigation: STT abstracted behind an internal interface; text-input path always available; Resilience4j stt

		circuit breaker prevents cascading failures.
Supabase (managed Postgres)	Hosts the relational database via pgbouncer transaction-mode pooler. Schema is applied manually via the SQL editor.	Medium — the pgbouncer pooler constrains tooling choices (no Flyway, prepareThreshold=0, asyncpg statement_cache_size=0). Mitigation: documented in docs/post-mortem/2026-04-22-backend-boot-and-schema.md; HikariCP and asyncpg both configured for pgbouncer compatibility.
Twilio WhatsApp / Meta Cloud API	Outbound WhatsApp delivery for appointment confirmation/cancellation and SOAP-finalized meds & follow-up reminders. Provider configurable via WHATSAPP_PROVIDER env (stub / twilio / meta-cloud).	Medium — 24h messaging window and pre-approved templates required by Meta; Twilio sandbox needs opt-in. Mitigation: outbox pattern decouples send from request path; failures retry with exponential backoff; stub provider keeps dev unblocked. Patient phone is never logged in plaintext (SHA-256 hash only).

4.5. DevOps & Deployment

This section captures the operational practices that make CliniFlow AI deployable, observable, and recoverable. Monitoring is covered in Section 4.2; this section covers everything else.

Schema management — important correction: Flyway was initially planned but removed because it is incompatible with Supabase's pgbouncer transaction-mode pooler (prepared-statement cache collisions on boot). The `backend/src/main/resources/db/migration/*.sql` files remain in the repo as **reference documentation only** — they are never executed automatically. Schema changes are applied **manually via the Supabase SQL editor** (or `supabase db push`) in the same version order (V1 → V8). JPA is configured with `ddl-auto: none` so Hibernate never touches DDL. Neo4j schema (constraints + indexes) is applied at FastAPI startup from `agent/app/graph/schema.py::apply_schema`, using idempotent `IF NOT EXISTS` statements.

4.5.1. CI/CD Pipeline

Platform: GitHub Actions (free tier covers hackathon and pilot-scale usage).

Pipeline stages:

1. *Lint & format* — Checkstyle/Spotless for Java, Ruff/Black for Python. Fast-fail.
2. *Test* — JUnit 5 + Testcontainers for Spring Boot integration tests, pytest for Python unit tests.
3. *Build & scan* — Maven package, Docker image build, Trivy scan for known CVEs in base images.
4. *Publish* — Tag and push images to GitHub Container Registry with both `latest` and `sha-{commit}` tags.
5. *Deploy* — On push to `main`, auto-deploy to staging. Manual `workflow_dispatch` promotes staging to production.

Branch protection on `main`: require PR review, require CI green, disallow force pushes. Not strictly necessary for a solo developer, but signals production-readiness and catches mistakes.

4.5.2. Containerization Strategy

Both services ship as multi-stage Docker images:

- *Spring Boot:* `eclipse-temurin:21-jdk` for build, `eclipse-temurin:21-jre-alpine` for runtime. Target image size ~200MB.
- *Python agent:* `python:3.12-slim` base with multi-stage wheel caching. Target image size ~300MB.

Compose topology (five services):

- `frontend` (Next.js standalone, `node:20-alpine`, EXPOSE 3000)
- `backend` (Spring Boot 3.3 / Java 21, `eclipse-temurin:21-jre-alpine`, EXPOSE 8080, depends on `agent`)
- `agent` (FastAPI / Python 3.12, `python:3.12-slim`, EXPOSE 8000, depends on `neo4j` healthy; **internal-only — no published port**)
- `neo4j` (`neo4j:5.20-community`, ports 7474 / 7687 with healthcheck via cypher-shell)
- `nginx` (`nginx:1.27-alpine`, port 80 — routes `/api/*` to backend, `/*` to frontend, `proxy_read_timeout 300s`, `client_max_body_size 25MB`)

Override files: `docker-compose.dev.yml` (hot reload, source mounts, exposed ports), `docker-compose.prod.yml` (resource limits, restart policies).

4.5.3. Logging & Correlation

Both services emit structured JSON logs to stdout, captured by Docker and shipped to Grafana Loki. Each log line carries:

- `timestamp` (ISO 8601)
- `level` (INFO/WARN/ERROR)
- `service` (spring-boot | python-agent)
- `correlation_id` — generated at the API gateway on every incoming request, propagated via the `X-Correlation-ID` HTTP header to the Python agent and included in every downstream log line
- `visit_id`, `doctor_id`, `patient_id` where applicable (hashed in non-audit logs)

This makes end-to-end tracing across the polyglot boundary a one-line query: `{correlation_id="abc123"}` in Loki returns every log emitted for that consultation by either service.

Separate PDPA audit log: append-only, written to its own PostgreSQL table. Records every read and write of patient data with timestamp, actor, action, resource ID. Retained per PDPA retention requirements and never mixed with application logs.

4.5.4. Secrets Management

- *Local development:* `.env.example` committed with placeholder keys; developers copy to `.env` (git-ignored) with local values.
- *CI:* secrets stored as GitHub Actions Secrets, injected as env vars during build/deploy.
- *Production:* docker-compose reads from host environment; production host uses `.env.prod` (file permissions 600, owned by deploy user) as the staging ground.

Never committed: Z.AI GLM API key, STT API key, PostgreSQL credentials, Neo4j credentials, Sentry DSN. Pre-commit hook (detect-secrets) blocks accidental commits of key-like strings.

Future: migrate to a secrets manager (AWS Secrets Manager or HashiCorp Vault) when scaling beyond pilot.

4.5.5. Database Migrations

Flyway is NOT used — it was evaluated and removed. Supabase's pgbouncer pooler (transaction mode) collides with Flyway's use of session-scoped prepared statements during its migration lock, causing the backend to fail at boot. See post-mortem `docs/post-mortem/2026-04-22-backend-boot-and-schema.md` for full detail.

Instead:

- PostgreSQL migrations live in `backend/src/main/resources/db/migration/` as **versioned SQL files for human reference** (V1 through V14 as of 2026-05-02 — V1 baseline, V2 evaluator + drug validation, V3 post-visit bilingual, V4 consent, V5 agent_turns, V6 visit report jsonb, V7 agent_turn audit trigger, V8 medical_reports review columns, V9 registration / doctors / staff / clinical profiles / projection outbox, V10

bootstrap admin, V11 schedule + notifications, V12 appointment checked_in, V13 audit action index, V14 visit reference counter). They are not auto-applied. Apply in order via the Supabase SQL editor or `supabase db push`. **Known repo quirk:** V2 has two files (`V2__seed_dev_users.sql` and `V2__evaluator_and_drug_validation.sql`) — a naming collision that has been applied in commit-history order; future migrations should not reuse a version number.

- Spring Boot runs with `spring.jpa.hibernate.ddl-auto: none`. Hibernate must never touch DDL — `validate` was tried and blocked startup whenever a manually-applied migration diverged by a single column.
- Supabase HikariCP is configured with `prepareThreshold: 0` and `preparedStatementCacheQueries: 0` to coexist with pgbouncer transaction mode. Python agent's asyncpg pools use `statement_cache_size=0` for the same reason.
- Three DB-level invariants worth highlighting: `audit_log` and `agent_turns` have BEFORE UPDATE / BEFORE DELETE triggers that raise an exception (append-only by PDPA design). `evaluator_findings` uses partial indexes that make the soft-block gate an index-only scan. Never UPDATE or DELETE the audit tables from application code; always INSERT.

For **Neo4j**, the schema (constraints + indexes) is enforced in code at FastAPI startup via `agent/app/graph/schema.py::apply_schema`, invoked from the FastAPI lifespan. All statements use `IF NOT EXISTS` so re-runs are idempotent.

4.5.6. Resilience Patterns

External calls (GLM, STT) use **Resilience4j** in Spring Boot with three patterns:

- *Circuit breaker* — opens if error rate exceeds 50% in a rolling window; half-open after 30s to probe recovery. Prevents cascading failures.
- *Rate limiter* — caps per-doctor request rate to avoid runaway token costs from stuck agents or malformed prompts.
- *Timeout* — strict per-call limits (8s for GLM, 15s for STT). Exceeded timeouts surface as degraded-path fallbacks, not error screens.

The Python agent service uses equivalent patterns via `tenacity` for retries and a lightweight in-memory rate limiter.

---

5. Project Management & Team Contributions

The project began as 7 days of solo development for the hackathon preliminary round and has continued through ongoing hardening. Scope is delivered phase-by-phase, with each phase gated by an end-to-end demo and a post-mortem if anything broke.

5.1. Project Timeline & Milestones

Preliminary round (7-day solo sprint): Spring Boot + FastAPI scaffold, Pre-Visit Agent, Report Agent (voice/text/upload), bilingual post-visit summary, patient + doctor portals end-to-end demo.

Post-prelim milestones (delivered to date, 2026-05-02):

Milestone	Scope	Status
Cross-patient PHI leak fix (post-mortem 2026-04-30)	Removed hardcoded patientId UUID; identity now derived from JWT principal; ownership check on every per-patient endpoint; cancelled 65 contaminated visits; codified the rule in docs/details/identity-and-authz.md.	Done
WhatsApp notifications (V11)	Outbox pattern, drainer scheduler, Twilio + Meta Cloud providers, consent gate, SHA-256 phone hash audit.	Done
Admin portal	User management drawer (role/active/force-reset), analytics KPIs + 30-day sparkline, PDPA audit log viewer.	Done
Neo4j projection drainer (V9)	Outbox pattern from Spring to Neo4j; idempotent projection of clinical aggregates.	Done
Hermes adaptive-rule write side	Read side built (rules injected into Report agent prompt); write side currently NotImplementedError.	Deferred
E-prescription PDF generation	Patient portal shows the e-prescription view; PDF download is stubbed.	Deferred

5.2. Team Members Role

Person	Role	Responsibilities
Tang Shao Xian	Solo Developer (Full Stack + AI)	Spring Boot backend (DDD bounded contexts), FastAPI agent service (LangGraph), React frontend, graph KB schema

		design, adaptive rule engine, GLM integration, system documentation

5.3. Recommendations

1. **Redis cache** for frequently accessed patient context from the graph KB, reducing Neo4j query load during peak hours.
2. **Prompt versioning** to track and rollback prompt templates when GLM output quality degrades.
3. **Structured logging with correlation IDs** across Spring Boot and Python services — already implemented; continue to enforce `X-Correlation-ID` propagation on every new service-to-service call.
4. **Adaptive rule confidence scoring** — once Hermes write side is implemented, only apply rules with ≥80% doctor-acceptance rate; auto-pause rules that fall below 50% over 24h (already specified, not yet wired because write side is deferred).
5. **Real-time evaluator SSE per validator** — stream `validator.started` / `validator.done` events so the safety panel can show progressive findings during slow Cypher or LLM calls; estimated 2–3 days.
6. **Drug-knowledge governance** — establish a clinical-pharmacist sign-off cadence and update process for `drug_knowledge.json`. The seed bundle is sufficient for MVP but needs a documented update path before broader pilot.
7. **Severity-mapping configurability** — the MAJOR→CRITICAL / MODERATE→HIGH / MINOR→LOW DDI mapping is currently hard-coded. Consider per-clinic or per-drug-class overrides for clinics with stricter or more permissive policies.
8. **PDPA review of override-reason content** — free-text `evaluator_findings.acknowledgement_reason` may contain incidental PHI. Define a redaction or aggregation policy before any trend analysis.
9. **Audit retention policy** — `audit_log` is unbounded today. Define a retention window (likely 7 years per Malaysian medical record retention norms) and an archival path that preserves append-only invariant.
10. **Visit-creation audit gap** — the 2026-04-30 incident exposed that `VISIT.CREATE` did not write an audit row, so the 65 contaminated visits could not be reattributed. Confirm every aggregate-create path writes audit (regression test recommended).